

# IDENTITY & ACCESS MANAGEMENT

## On-Premises Active Directory Implementation

Windows Server 2022 | Elon.io Domain

---

### Technical Project Documentation

#### Forest Domain: Elon.io

Scope: AD DS Configuration | OU Structure | User Provisioning | GPO Management | IAM  
Governance

Date: 24 June 2026

## Table of Contents

---

|                                                                           |    |
|---------------------------------------------------------------------------|----|
| <b>1. Executive Summary</b>                                               | 3  |
| <b>2. Project Overview &amp; Objectives</b>                               | 4  |
| <b>3. Environment &amp; Infrastructure</b>                                | 5  |
| <b>4. Active Directory Installation &amp; Domain Controller Promotion</b> | 5  |
| <b>5. Organisational Unit (OU) Design</b>                                 | 7  |
| <b>6. Identity Lifecycle — User &amp; Group Provisioning</b>              | 8  |
| 6.1 Naming Convention & UPN Standard                                      | 8  |
| 6.2 Group Structure per OU                                                | 9  |
| 6.3 Full User Provisioning Register                                       | 9  |
| <b>7. Group Policy Object (GPO) Design &amp; Implementation</b>           | 11 |
| 7.1 Default Domain Password Policy GPO                                    | 11 |
| 7.2 Restricted Access GPO — Control Panel & CMD Lockdown                  | 13 |
| 7.3 Additional GPOs — IAM Security Hardening                              | 14 |
| <b>8. GPO Security Filtering &amp; Scope Management</b>                   | 17 |
| <b>9. Identity Lifecycle Management (Joiner / Mover / Leaver)</b>         | 18 |
| <b>10. AD Certificate Services — Overview &amp; Relevance</b>             | 20 |
| <b>11. IAM Incident &amp; Service Request Management</b>                  | 21 |
| <b>12. Key Competencies Demonstrated</b>                                  | 22 |
| <b>13. References &amp; Tools</b>                                         | 23 |

# 1. Executive Summary

---

This document presents the complete technical documentation for an on-premises Identity and Access Management (IAM) implementation carried out on Windows Server 2022 using Active Directory Domain Services (AD DS). The project simulates a production-grade enterprise IAM environment for BodeTech AI, encompassing forest domain creation, a structured Organisational Unit (OU) hierarchy, role-based group membership, a standardised user principal name (UPN) naming convention, and a comprehensive Group Policy Object (GPO) framework.

The implementation was designed to directly demonstrate competency across the core responsibilities of an IAM Administrator role, including: Active Directory user, group, and GPO administration; identity lifecycle management (Joiner, Mover, Leaver); GPO security filtering and scope management; and the foundational knowledge required to support Microsoft Identity Manager (MIM) and Active Directory Certificate Services (AD CS) in enterprise environments.



## 2. Project Overview & Objectives

### 2.1 Project Context

BodeTech AI is a simulated mid-sized technology organisation requiring an enterprise IAM foundation. This project models the real-world task of standing up an on-premises Active Directory environment from scratch, applying IAM best practices throughout: separation of administrative tiers, principle of least privilege, role-based access control (RBAC) via security groups, and enforceable security policy through GPOs.

### 2.2 Key Objectives

- Install and configure Active Directory Domain Services (AD DS) on Windows Server 2022.
- Promote the server to a Domain Controller and establish a new forest with root domain Elon.io.
- Design and implement a three-location OU hierarchy reflecting organisational geography.
- Provision user accounts and security groups following a standardised naming convention.
- Create and link GPOs for password policy enforcement, access restriction, and security hardening.
- Apply GPO security filtering to scope policies precisely to intended user populations.
- Demonstrate full understanding of the Joiner, Mover, and Leaver (JML) identity lifecycle process.
- Demonstrate awareness of adjacent IAM technologies: AD CS and Microsoft Identity Manager (MIM).

### 2.3 IAM Role Alignment

This project was designed to evidence the following core IAM administrator competencies:

| Role Requirement                              | Project Evidence                                                            |
|-----------------------------------------------|-----------------------------------------------------------------------------|
| Administer AD users, groups and GPOs          | Full AD DS build — OU design, user/group provisioning, 6+ GPOs              |
| Support Microsoft Identity Manager (MIM)      | JML process design; attribute mapping and provisioning patterns documented  |
| Manage Joiner, Mover and Leaver processes     | Dedicated JML workflow section with step-by-step AD procedures              |
| Support Active Directory Certificate Services | AD CS overview, PKI hierarchy understanding, certificate template awareness |
| Resolve IAM incidents and service requests    | Incident categorisation, resolution steps, and escalation paths documented  |

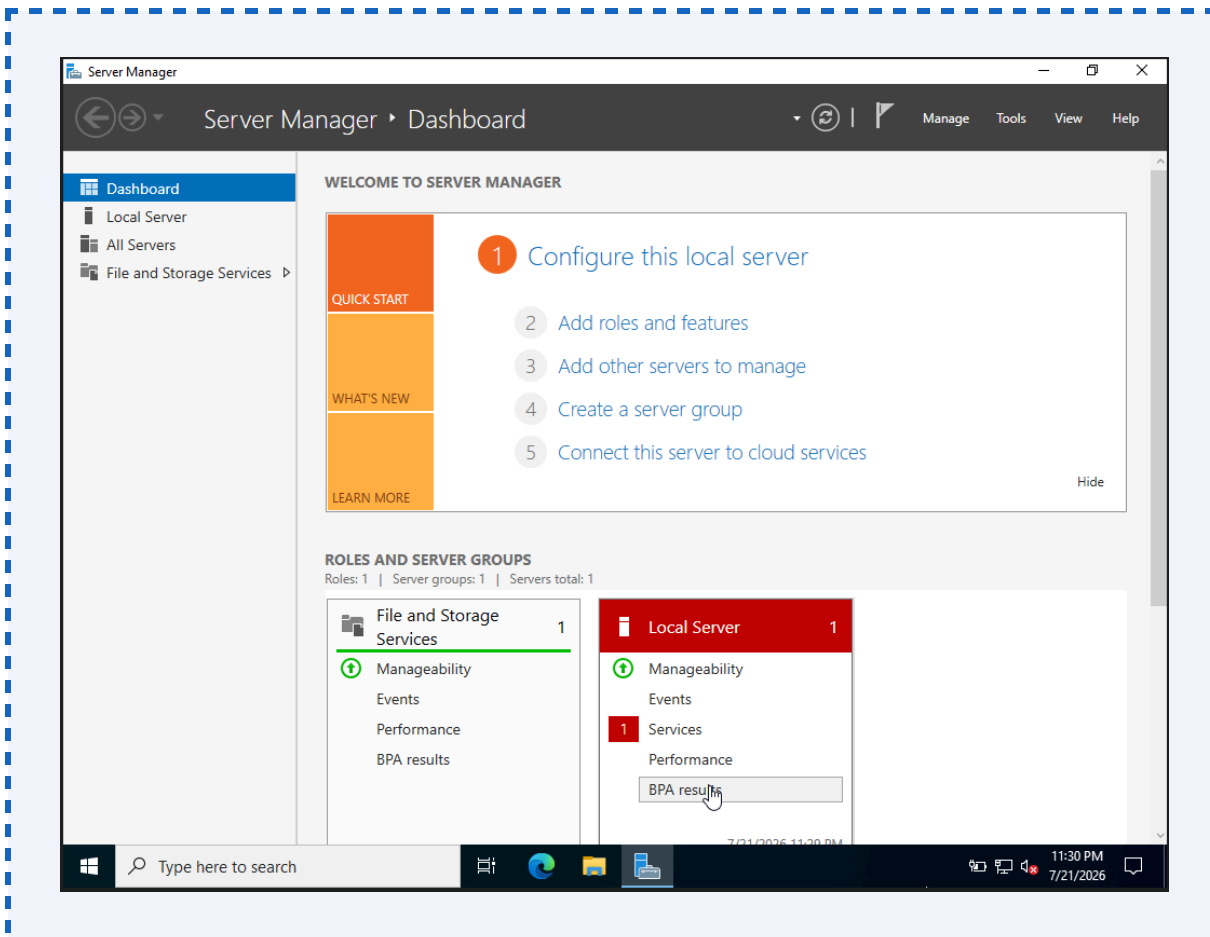
### 3. Environment & Infrastructure

|                                  |                                                                                                        |
|----------------------------------|--------------------------------------------------------------------------------------------------------|
| Operating System                 | Windows Server 2022 Standard (Desktop Experience)                                                      |
| Role Installed                   | Active Directory Domain Services (AD DS)                                                               |
| Forest Root Domain               | Elon.io                                                                                                |
| Domain Controller Name           | DC01 (Primary Domain Controller — PDC Emulator)                                                        |
| Forest / Domain Functional Level | Windows Server 2016 (compatible with modern AD features)                                               |
| DNS                              | Integrated AD DNS configured on DC01 — authoritative for Elon.io zone                                  |
| SYSVOL / NETLOGON                | Automatically provisioned on DC01; replicated via DFSR                                                 |
| Global Catalog                   | DC01 configured as Global Catalog server                                                               |
| Administrative Tool              | Active Directory Users and Computers (ADUC), Group Policy Management Console (GPMC), PowerShell (RSAT) |

## 4. Active Directory Installation & Domain Controller Promotion

### 4.1 Server Preparation

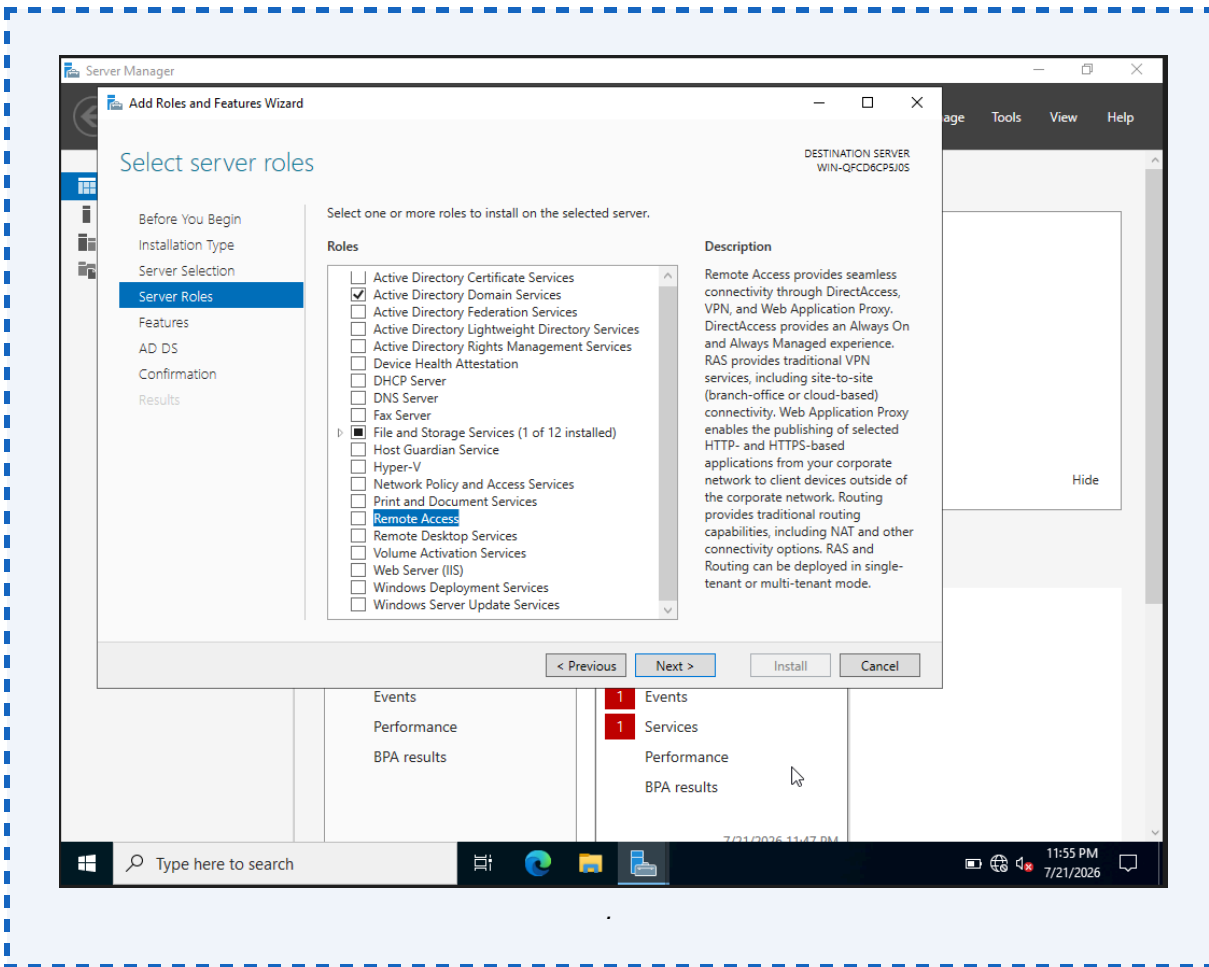
Prior to AD DS installation, the server was configured with a static IP address, a consistent hostname (DC01), and verified network connectivity. Windows Server 2022 was fully patched and all pending updates applied to ensure a stable baseline.



### 4.2 AD DS Role Installation

The Active Directory Domain Services role was installed via Server Manager using the Add Roles and Features Wizard. The following role and associated features were selected:

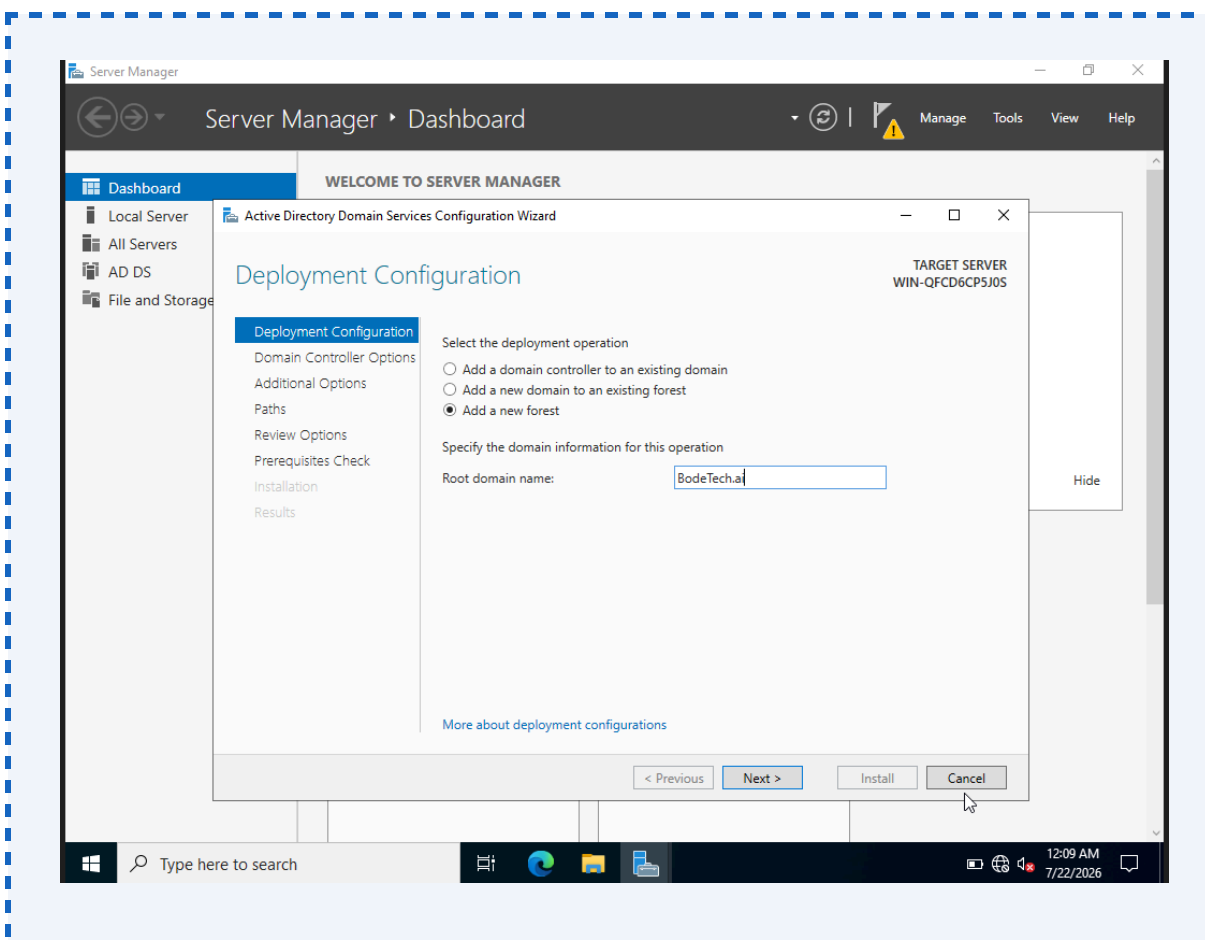
- Role: Active Directory Domain Services
- Feature: Group Policy Management (automatically included)
- Feature: Remote Server Administration Tools — AD DS Tools
- Feature: DNS Server (selected to support AD-integrated DNS)

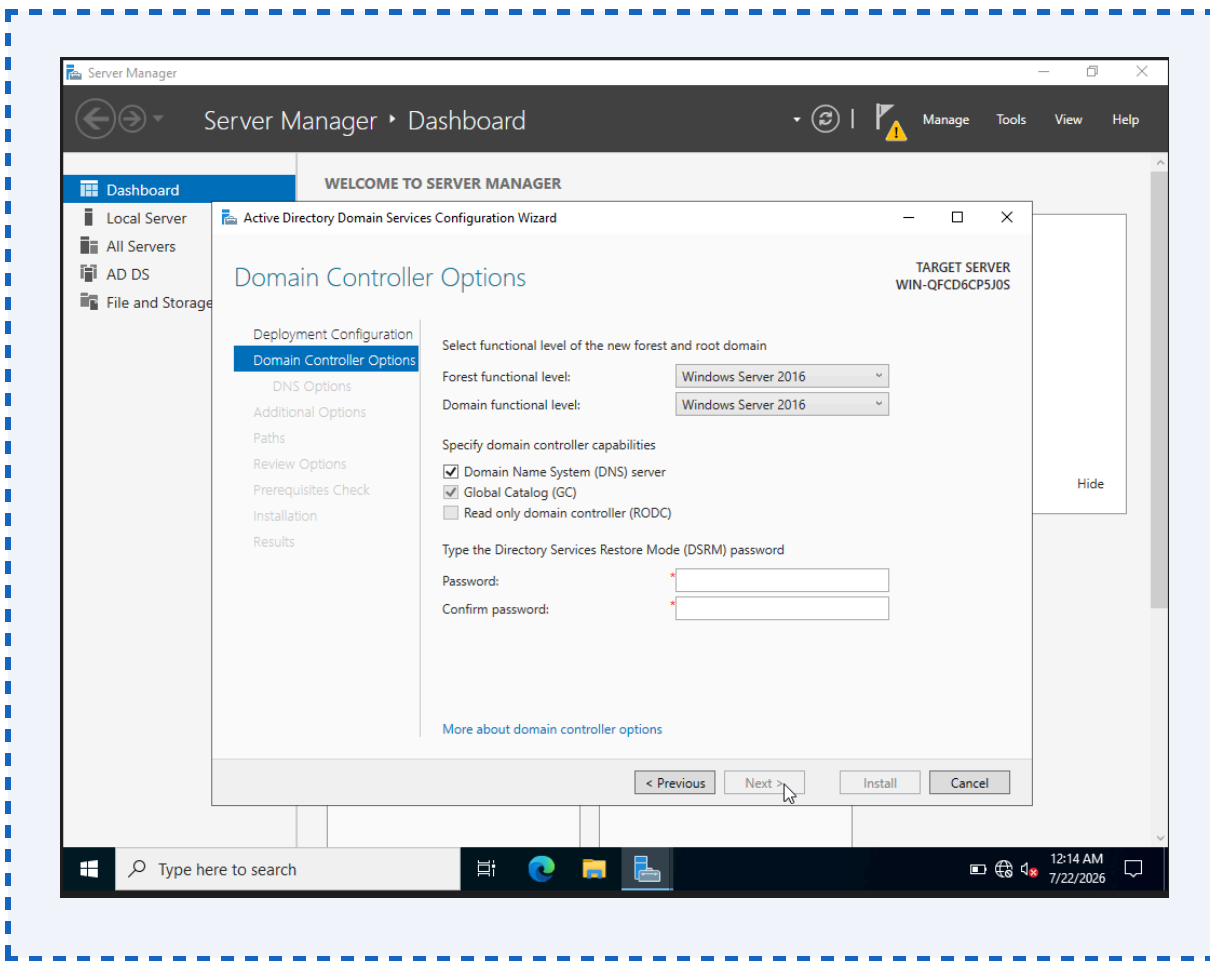


### 4.3 Domain Controller Promotion — New Forest

Following role installation, the server was promoted to a Domain Controller using the Active Directory Domain Services Configuration Wizard. The following configuration was applied:

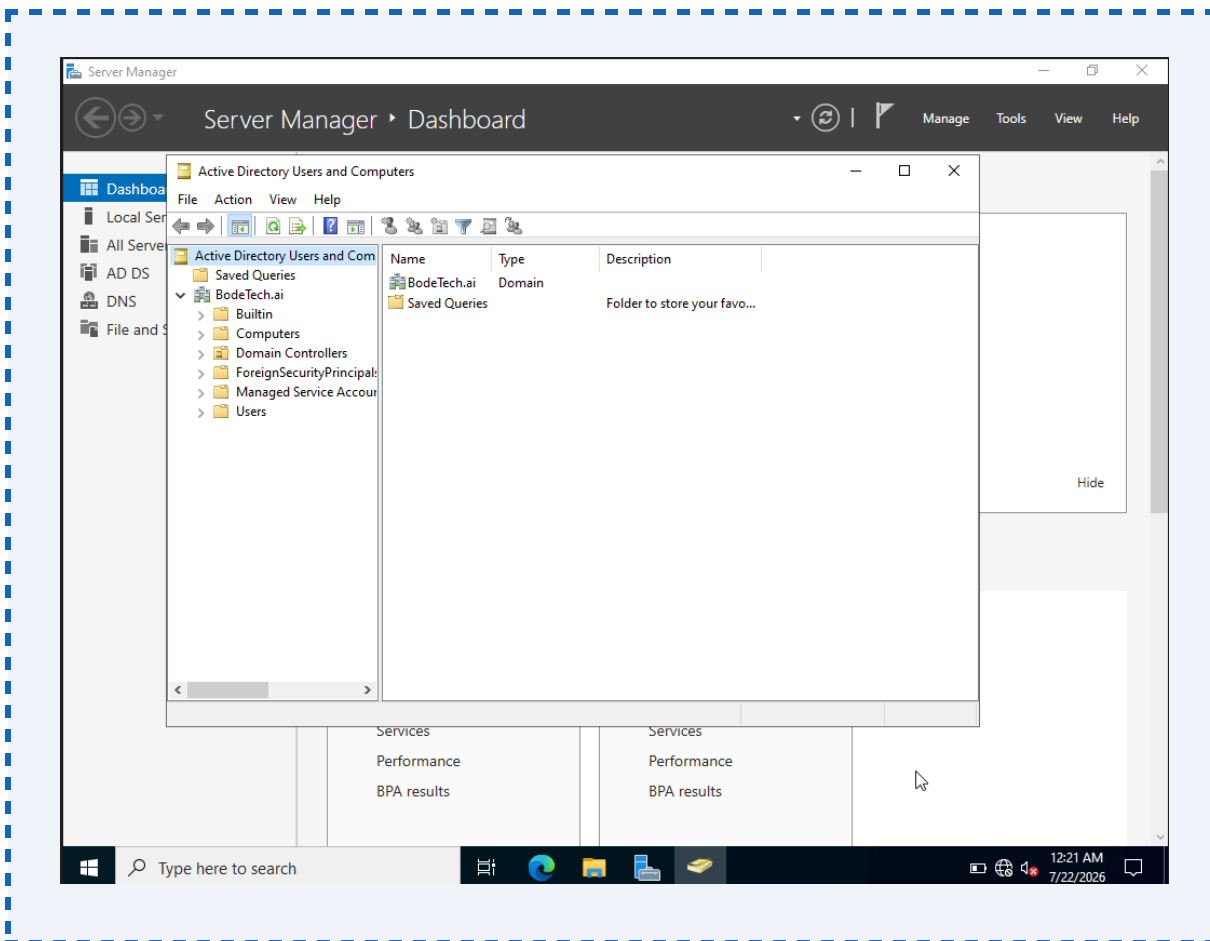
| Configuration Parameter                | Value Applied                                       |
|----------------------------------------|-----------------------------------------------------|
| Deployment Operation                   | Add a new forest                                    |
| Root Domain Name                       | Elon.io                                             |
| Forest Functional Level                | Windows Server 2012                                 |
| Domain Functional Level                | Windows Server 2012                                 |
| Domain Controller Capabilities         | DNS Server, Global Catalog (GC)                     |
| Directory Services Restore Mode (DSRM) | Strong DSRM password configured and stored securely |
| NetBIOS Domain Name                    | BODETECH                                            |
| AD DS Database Path                    | C:\Windows\NTDS                                     |
| SYSVOL Path                            | C:\Windows\SYSVOL                                   |
| DNS Delegation                         | Not created (single-domain lab environment)         |





Upon completion of the configuration wizard, the server performed an automatic restart.  
Post-restart verification confirmed:

- AD DS services (NTDS, KDC, Netlogon) running and set to Automatic start
- DNS zones for Elon.io and \_msdcs.Elon.io created and resolving correctly
- SYSVOL and NETLOGON shares accessible from the network
- Default AD objects (Domain Controllers OU, Builtin container, Users container) present in ADUC



### Administrative Note

Following DC promotion, the built-in Administrator account was secured with a complex password and a dedicated Domain Admin account was created for day-to-day administration, avoiding the use of the built-in account in line with IAM least-privilege principles.

## 5. Organisational Unit (OU) Design

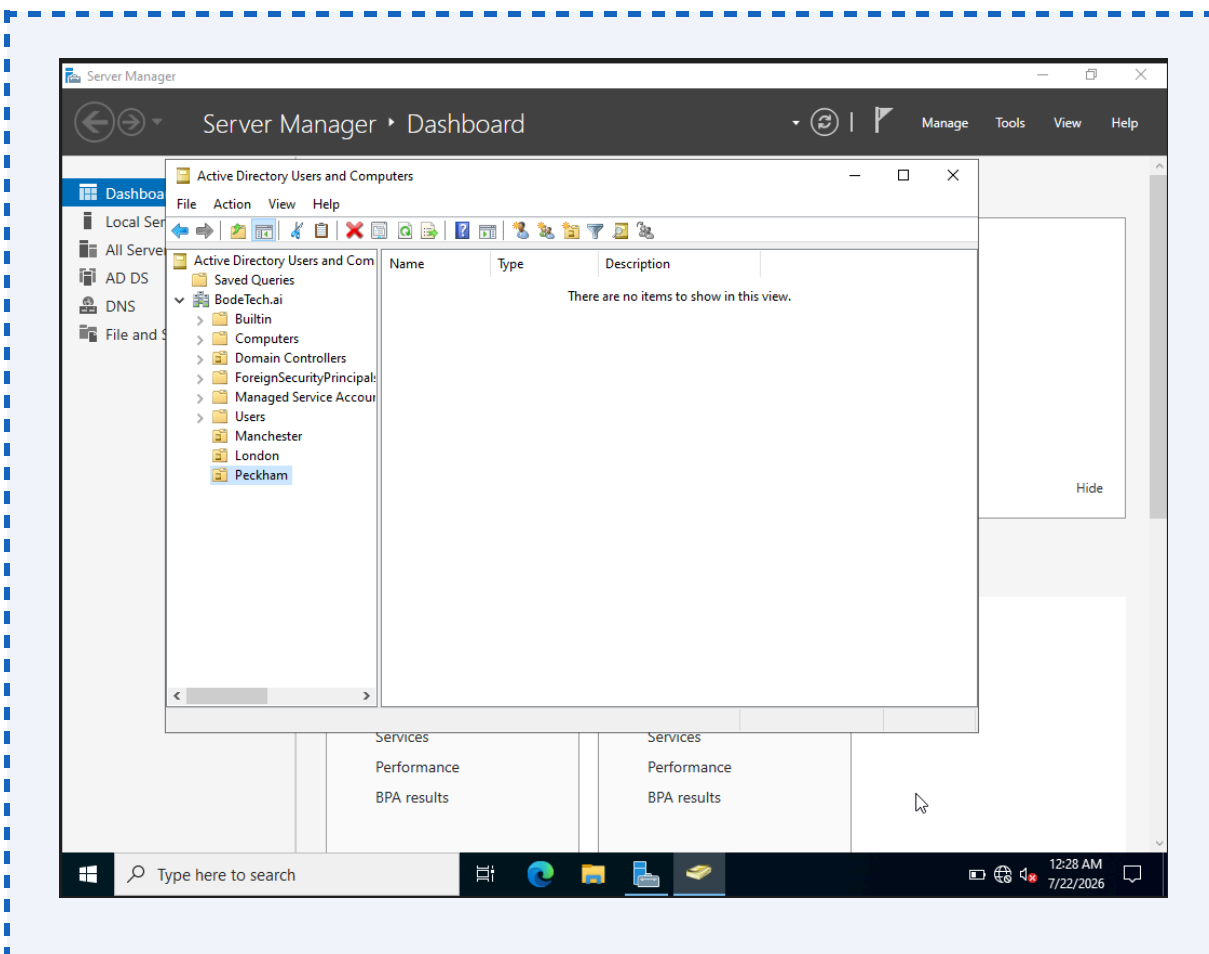
### 5.1 Design Rationale

The Organisational Unit hierarchy was designed to reflect BodeTech AI's geographic office locations, enabling location-scoped Group Policy application, delegated administration, and clear separation of identity objects. This mirrors the industry-standard practice of building OU structures that support both policy inheritance and delegated administrative control — a core principle in enterprise IAM and MIM-integrated environments.

### 5.2 OU Hierarchy

Three top-level OUs were created directly under the Elon.io domain root, each representing a physical office location:

| OU Name    | Distinguished Name (DN)         | Purpose                                                  |
|------------|---------------------------------|----------------------------------------------------------|
| Manchester | OU=Manchester,DC=BodeTech,DC=ai | Users, groups and workstations for the Manchester office |
| London     | OU=London,DC=BodeTech,DC=ai     | Users, groups and workstations for the London office     |
| Peckham    | OU=Peckham,DC=BodeTech,DC=ai    | Users, groups and workstations for the Peckham office    |



**GPO Inheritance Principle**

GPOs linked at the domain level apply to all three OUs by inheritance. OU-specific GPOs can be linked at the individual OU level to override or extend domain-level policy for specific locations or user populations — a pattern used in this project for targeted access restriction policies.

**5.3 OU Structure Diagram**

```
Elon.io   (Domain Root)
|
+-- OU=Manchester
|   +-- [Groups: HR, Finance]
|   +-- [Users: 4 accounts]
|
+-- OU=London
|   +-- [Groups: IT, Operations]
|   +-- [Users: 4 accounts]
|
+-- OU=Peckham
    +-- [Groups: Legal, Marketing]
    +-- [Users: 4 accounts]
```

## 6. Identity Lifecycle — User & Group Provisioning

### 6.1 Naming Convention & UPN Standard

A consistent, enterprise-grade naming convention was applied across all identities to support IAM governance, audit readiness, and integration with downstream systems such as Microsoft Identity Manager (MIM) and ITSM tooling.

#### UPN Naming Convention

Format: firstname.GroupName@Elon.io Example: aliu.HR@Elon.io — 'aliu' = user's first name (lowercased) — 'HR' = the security group the user's primary role belongs to — '@Elon.io' = the forest UPN suffix This convention embeds group membership context directly into the UPN, enabling rapid identity lookup, role identification from email/login alone, and streamlined integration with identity governance tooling.

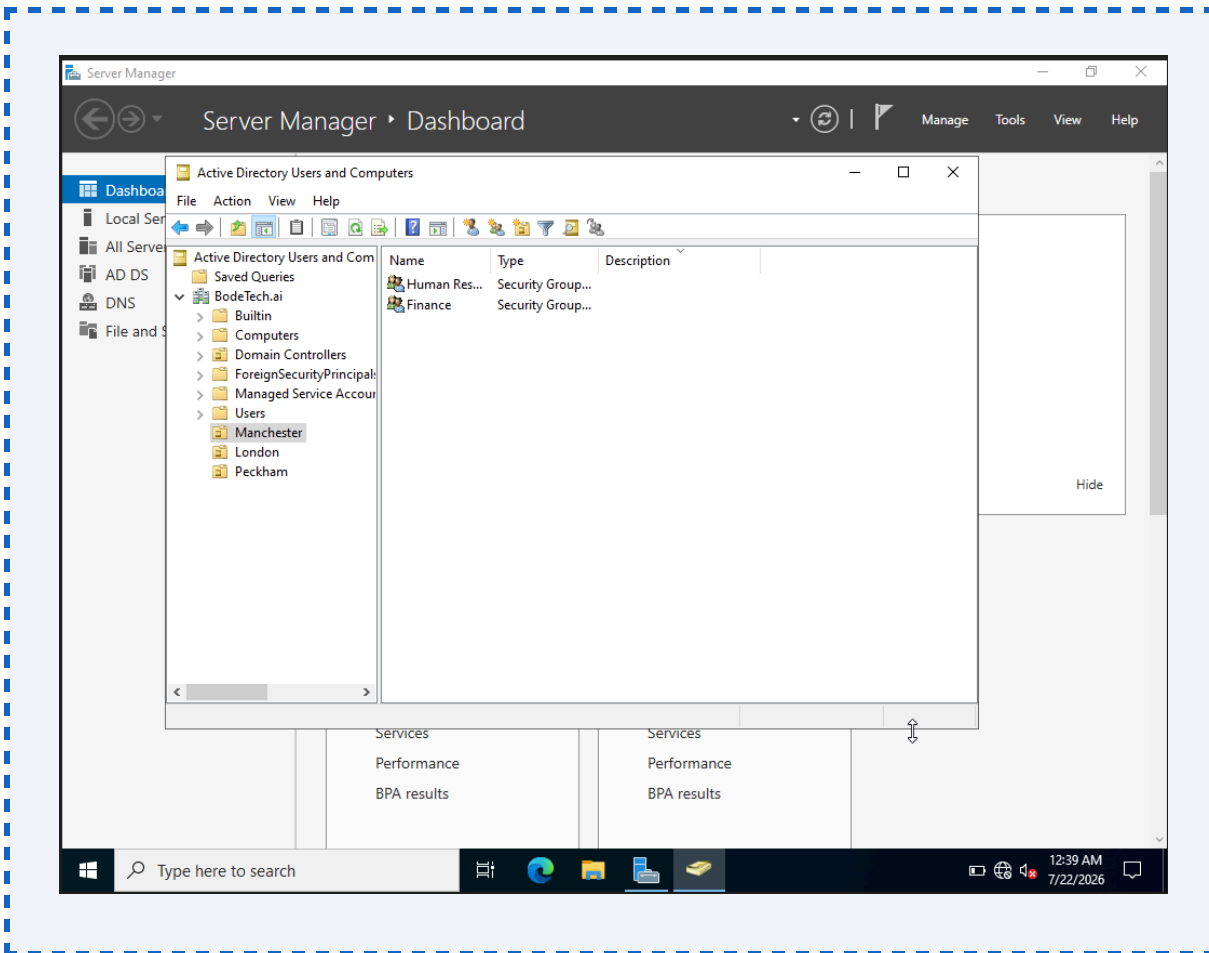
The UPN format serves multiple IAM governance purposes:

- Rapid identification of a user's business unit from their login credential alone
- Consistent attribute mapping for MIM connector synchronisation rules
- Reduced onboarding friction — account creation templates derived from group prefix
- Audit trail enrichment — UPN format aids correlation across AD logs, SIEM, and ITSM

### 6.2 Group Structure per OU

Two security groups were created within each OU, each reflecting a business function. All groups are Global Security Groups, aligned with RBAC best practice (resource access assigned at the group level, not to individual users).

| OU         | Group Name | Group DN                                   | Group Type / Scope    |
|------------|------------|--------------------------------------------|-----------------------|
| Manchester | HR         | CN=HR,OU=Manchester,DC=BodeTech,DC=ai      | Global Security Group |
| Manchester | Finance    | CN=Finance,OU=Manchester,DC=BodeTech,DC=ai | Global Security Group |
| London     | IT         | CN=IT,OU=London,DC=BodeTech,DC=ai          | Global Security Group |
| London     | Operations | CN=Operations,OU=London,DC=BodeTech,DC=ai  | Global Security Group |
| Peckham    | Legal      | CN=Legal,OU=Peckham,DC=BodeTech,DC=ai      | Global Security Group |
| Peckham    | Marketing  | CN=Marketing,OU=Peckham,DC=BodeTech,DC=ai  | Global Security Group |

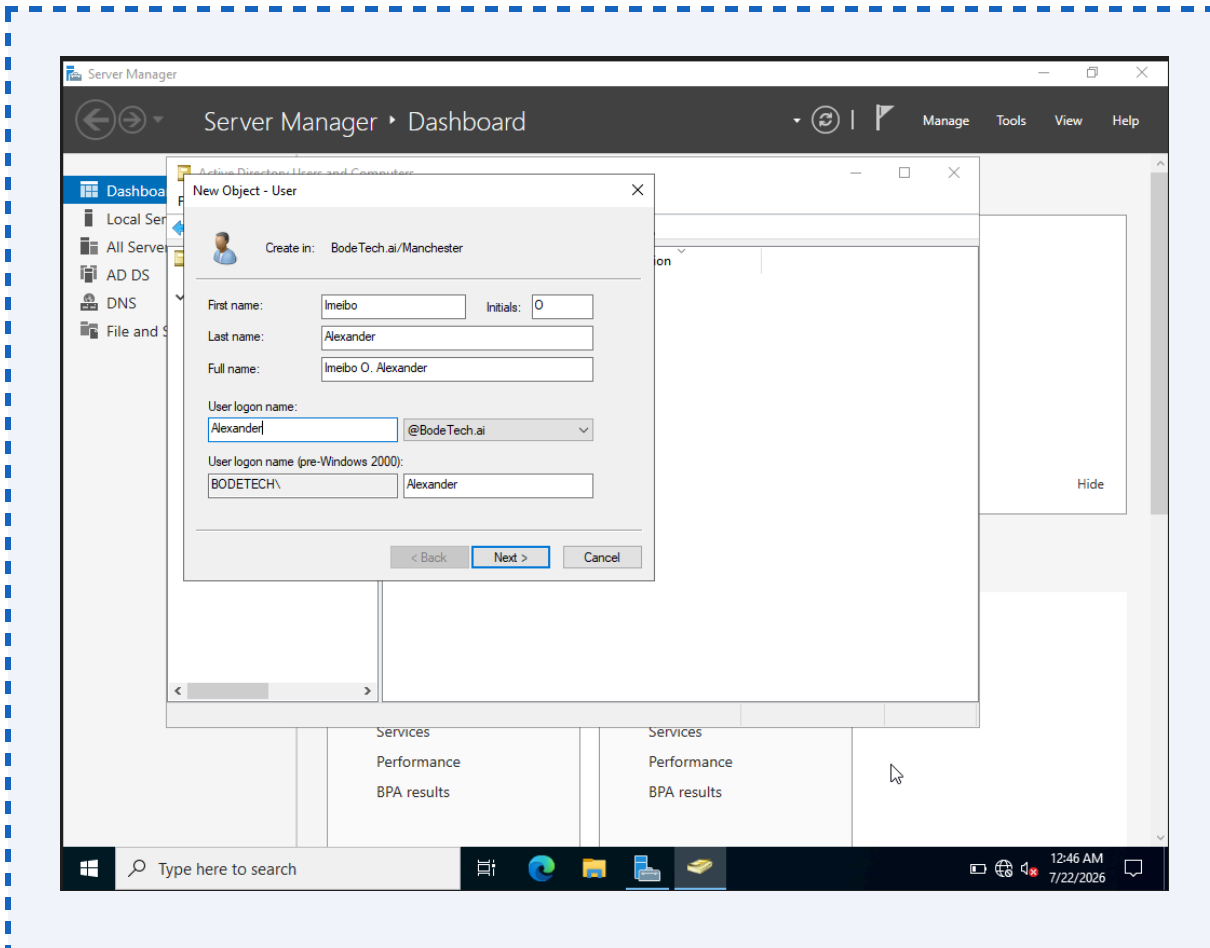


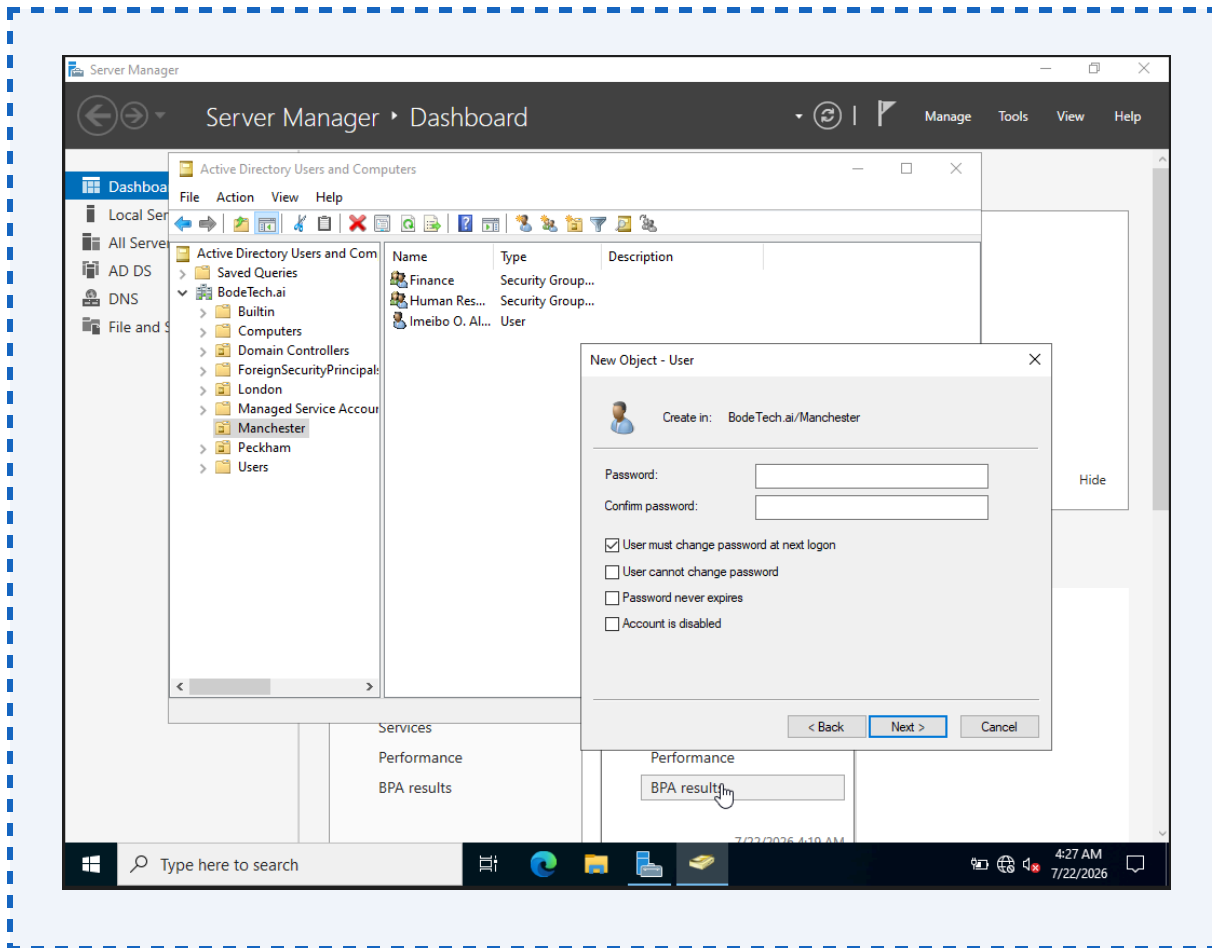
### 6.3 Full User Provisioning Register

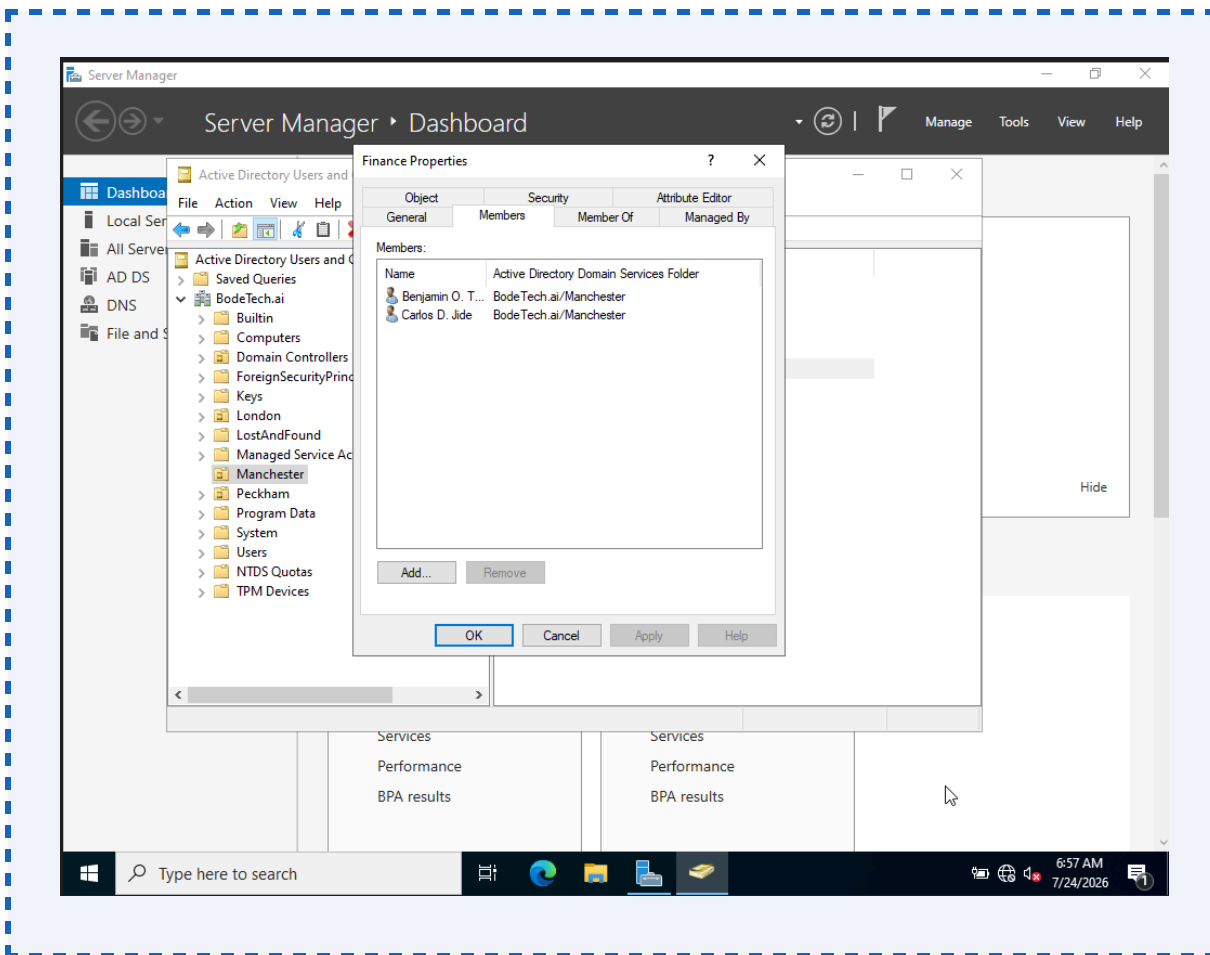
Two user accounts were created per group (12 accounts total). Each user was placed in the OU corresponding to their location and added to their group as a member. The table below constitutes the full identity provisioning register for the BodeTech AI domain.

| User Principal Name (UPN) | OU         | Group Membership | Display Name / Role            |
|---------------------------|------------|------------------|--------------------------------|
| aliu.HR@Elon.io           | Manchester | HR               | Aliu — HR Administrator        |
| bkemi.HR@Elon.io          | Manchester | HR               | Bkemi — HR Coordinator         |
| cjide.Finance@Elon.io     | Manchester | Finance          | Cjide — Finance Analyst        |
| dtunde.Finance@Elon.io    | Manchester | Finance          | Dtunde — Finance Officer       |
| eseun.IT@Elon.io          | London     | IT               | Eseun — IT Support Engineer    |
| fchidi.IT@Elon.io         | London     | IT               | Fchidi — Systems Administrator |
| gbola.Operations@Elon.io  | London     | Operations       | Gbola — Operations Manager     |
| hkola.Operations@Elon.io  | London     | Operations       | Hkola — Operations Analyst     |
| ileke.Legal@Elon.io       | Peckham    | Legal            | Ileke — Legal Counsel          |

|                         |         |           |                            |
|-------------------------|---------|-----------|----------------------------|
| jyemi.Legal@Elon.io     | Peckham | Legal     | Jyemi — Compliance Officer |
| kfemi.Marketing@Elon.io | Peckham | Marketing | Kfemi — Marketing Manager  |
| Isola.Marketing@Elon.io | Peckham | Marketing | Lsola — Brand Analyst      |





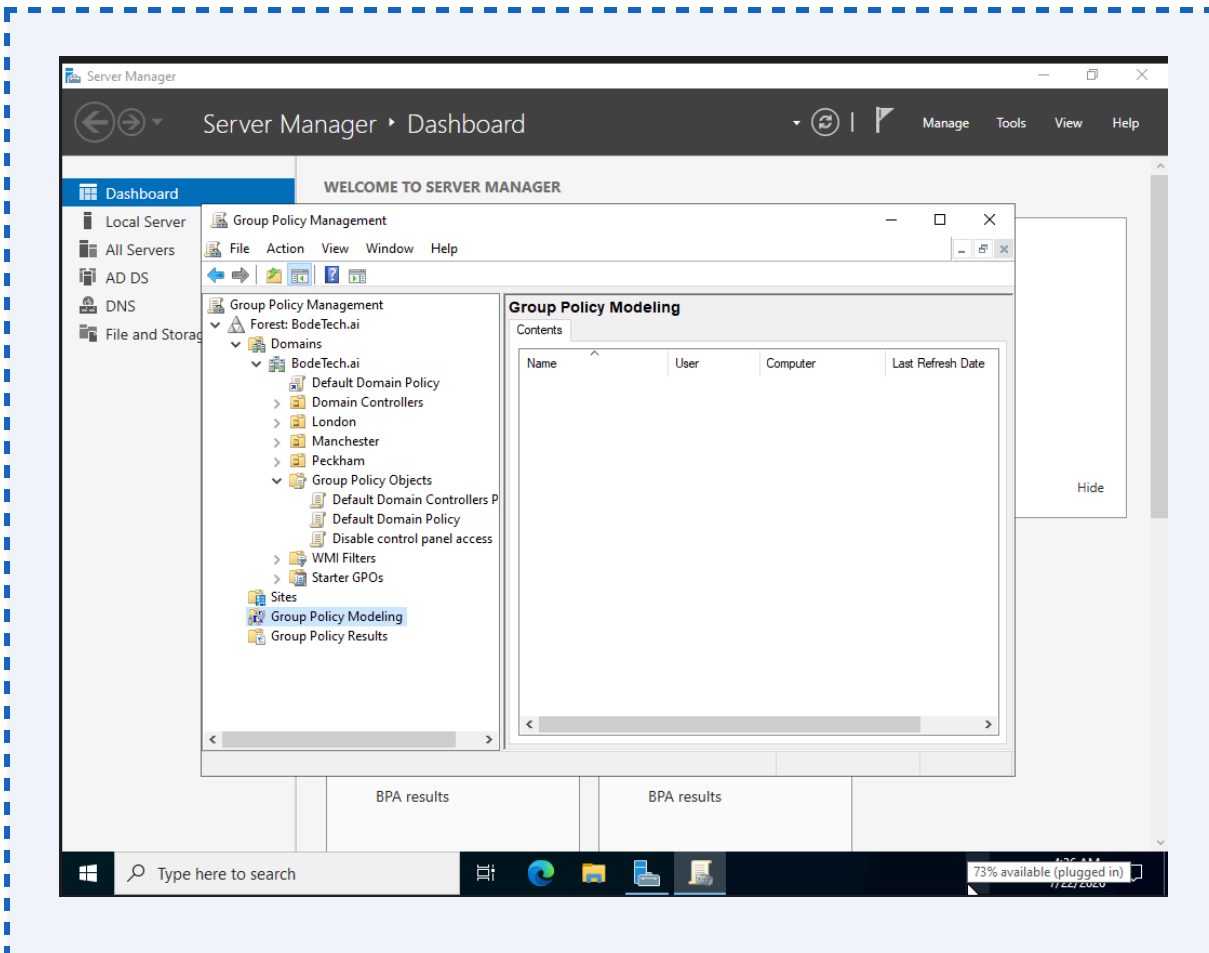


### Account Attribute Standards

All accounts were provisioned with: Account Enabled = True | Password must be changed at next logon = False (admin-set initial password) | User cannot change password = False | UPN set per naming standard | sAMAccountName set to match UPN prefix (e.g. aliu.HR) | Description field populated with job title | Department attribute set to match group name | Manager attribute set where applicable.

## 7. Group Policy Object (GPO) Design & Implementation

All GPOs were created and managed via the Group Policy Management Console (GPMC). Each GPO was created with a descriptive name, configured with specific settings, linked at the appropriate scope, and validated using the Group Policy Results (GPRESULT) and Group Policy Modelling tools.



### 7.1 Default Domain Password Policy GPO

#### 7.1.1 Purpose

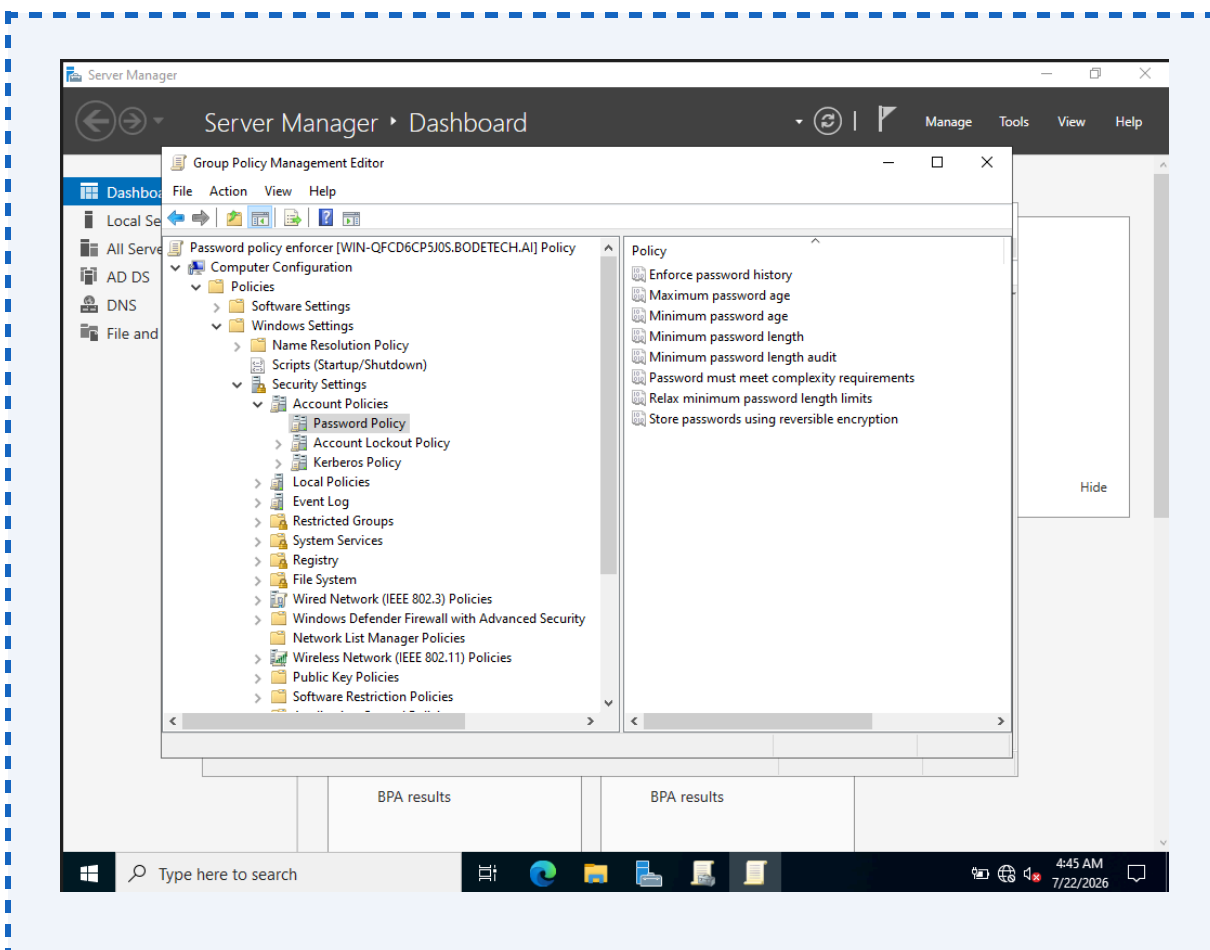
The Default Domain Password Policy GPO enforces password complexity, length, and rotation requirements domain-wide. In Active Directory, only one password policy can apply at the domain level via the Default Domain Policy GPO (or its equivalent). This project implemented a dedicated, clearly named GPO linked to the domain to make the policy intent explicit and auditable — a best practice in enterprise environments.

#### 7.1.2 GPO Configuration — Computer Configuration Path

Path: Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy

| Policy Setting | Configured Value | IAM Rationale |
|----------------|------------------|---------------|
|----------------|------------------|---------------|

|                                                    |                         |                                                                             |
|----------------------------------------------------|-------------------------|-----------------------------------------------------------------------------|
| <b>Enforce password history</b>                    | 24 passwords remembered | Prevents users from cycling back to previous passwords, reducing reuse risk |
| <b>Maximum password age</b>                        | 90 days                 | Limits the window of exposure for compromised credentials                   |
| <b>Minimum password age</b>                        | 1 day                   | Prevents immediate cycling to bypass history enforcement                    |
| <b>Minimum password length</b>                     | 12 characters           | Aligns with NCSC and NIST SP 800-63B guidance for enterprise accounts       |
| <b>Password must meet complexity requirements</b>  | Enabled                 | Requires uppercase, lowercase, digit, and special character mix             |
| <b>Store passwords using reversible encryption</b> | Disabled                | Prevents clear-text password storage — critical security control            |

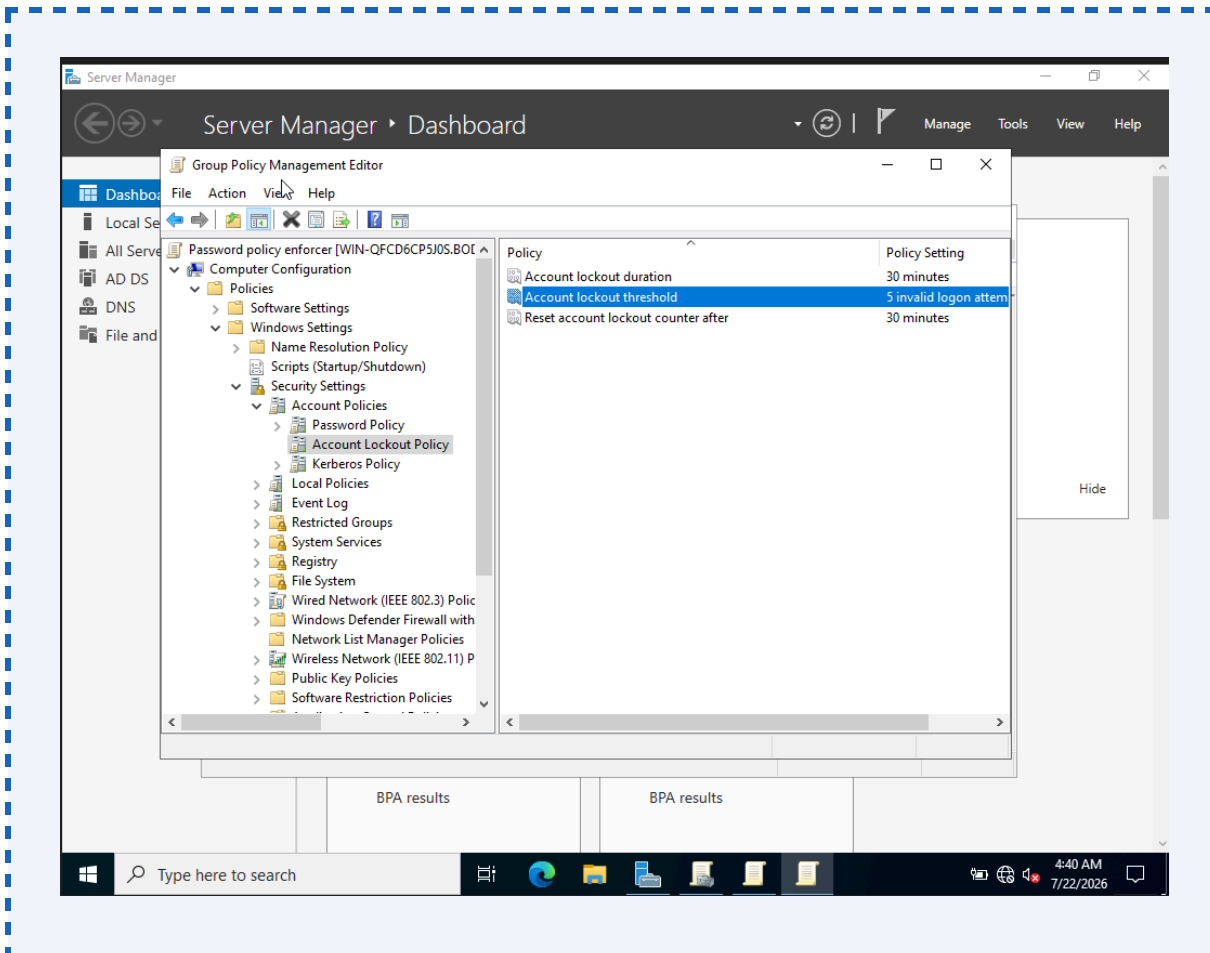


### 7.1.3 Account Lockout Policy

Path: Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Account Lockout Policy

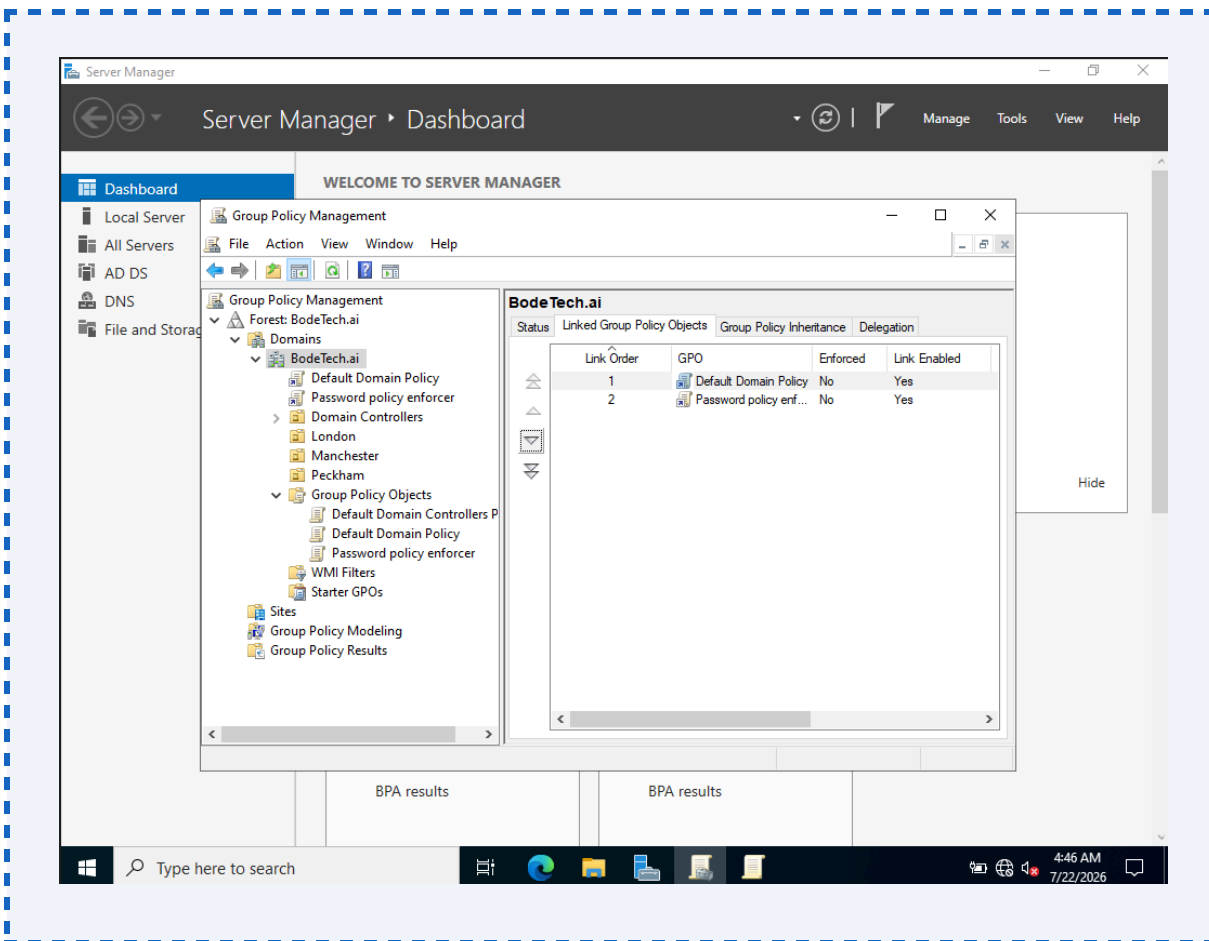
| Policy Setting | Configured Value | IAM Rationale |
|----------------|------------------|---------------|
|----------------|------------------|---------------|

|                                            |                    |                                                                        |
|--------------------------------------------|--------------------|------------------------------------------------------------------------|
| <b>Account lockout threshold</b>           | 5 invalid attempts | Prevents brute-force and credential stuffing attacks                   |
| <b>Account lockout duration</b>            | 30 minutes         | Auto-unlock reduces helpdesk burden while providing cooling-off period |
| <b>Reset account lockout counter after</b> | 30 minutes         | Resets failed attempt counter after sustained normal activity          |



#### 7.1.4 Linkage & Security Filtering

- GPO linked to: Elon.io (domain root)
- Link order: 1 (highest precedence at domain level)
- Enforcement: Enabled (prevents child OUs from blocking inheritance)
- Security Filtering: Authenticated Users (applies to all domain user and computer accounts)



## 7.2 Restricted Access GPO — Control Panel & CMD Lockdown

### 7.2.1 Purpose

This GPO was created to restrict a defined subset of standard users from accessing the Windows Control Panel and the Command Prompt (cmd.exe). This addresses a common IAM control requirement: limiting access to system configuration tools for non-administrative users, preventing unauthorized system changes and reducing the attack surface for lateral movement or privilege escalation.

### 7.2.2 GPO Configuration — User Configuration

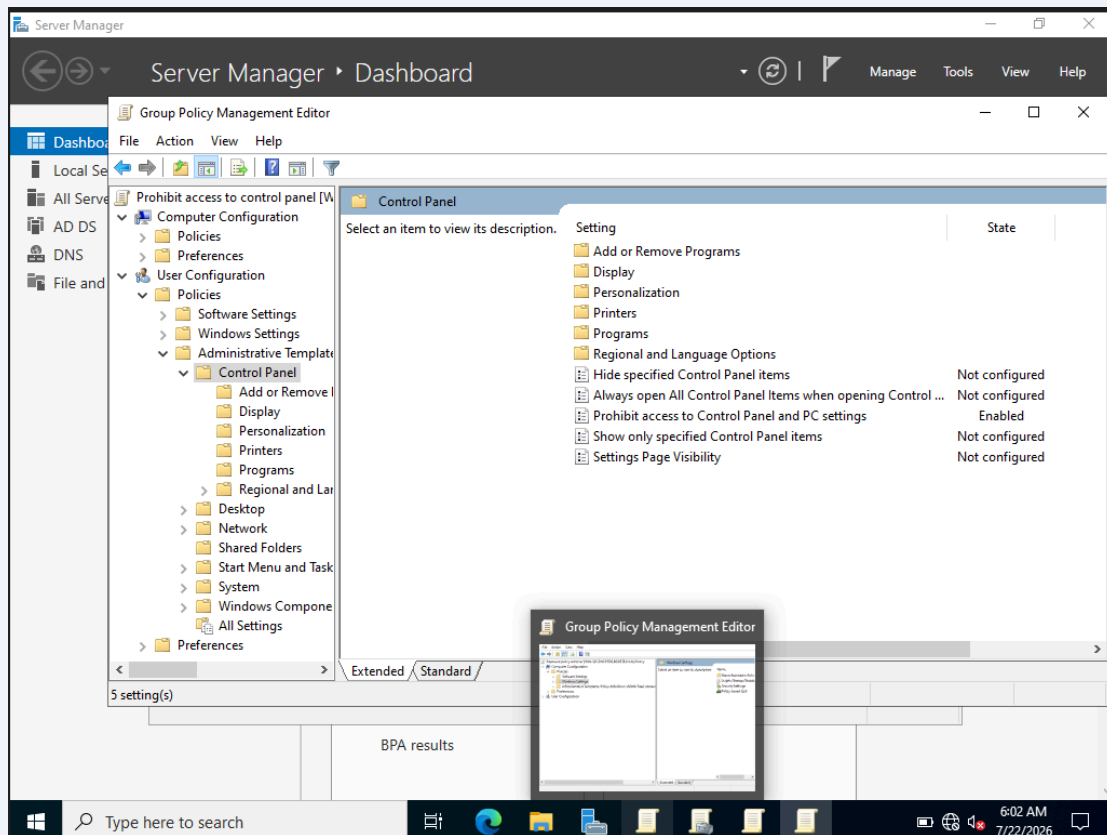
Path: User Configuration > Policies > Administrative Templates

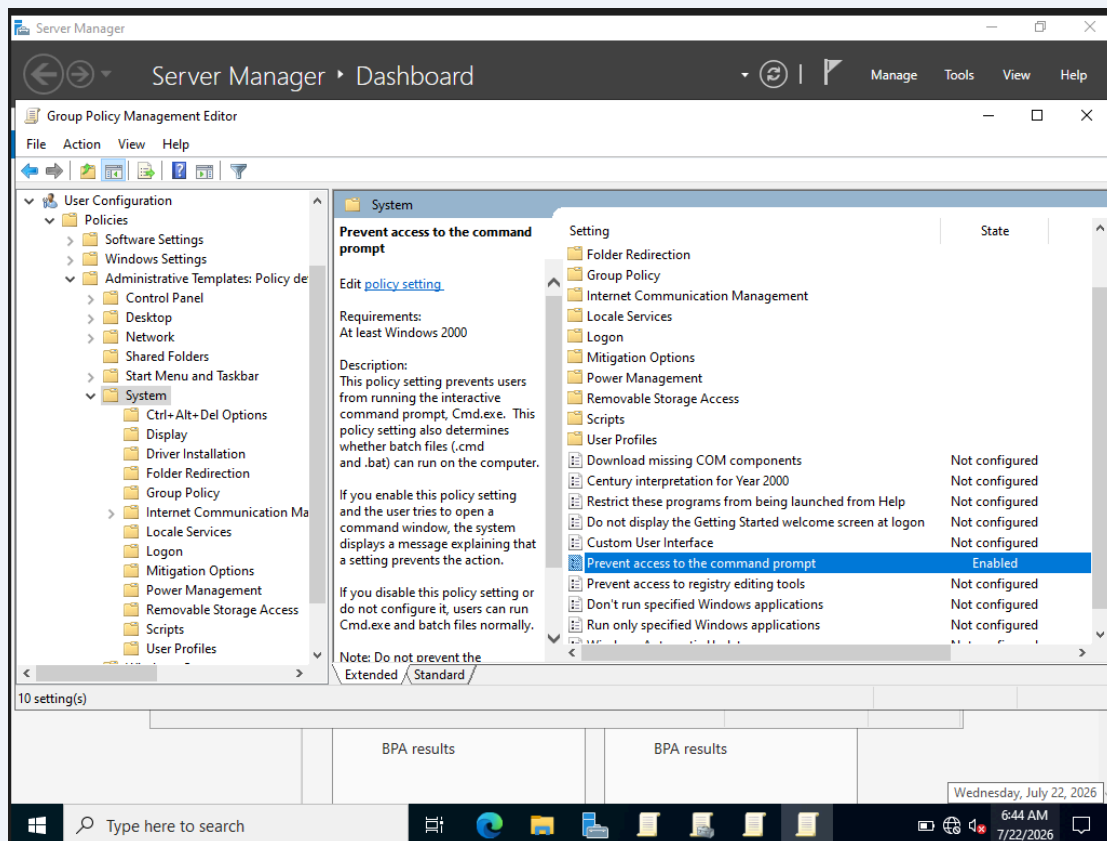
| Policy Path                                   | Setting                                                 | Value & Effect                                                                                           |
|-----------------------------------------------|---------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| Control Panel and Settings                    | <b>Prohibit access to Control Panel and PC Settings</b> | Enabled — removes Control Panel from Start Menu; direct access attempts produce an access denied message |
| System > Prevent access to the command prompt | <b>Prevent access to the command prompt</b>             | Enabled — blocks cmd.exe launch; also disables running of batch scripts to prevent script-based bypass   |

System > Prevent access to the command prompt

**Disable the command prompt script processing also**

Yes — ensures batch files (.bat, .cmd) are also blocked, preventing indirect cmd access





### 7.2.3 Linkage & Targeting

- GPO linked to: Elon.io (domain root) — applies domain-wide by inheritance
- Security Filtering: Applied to specific user accounts / group (e.g., non-IT staff) — IT group excluded via Deny GPO Apply permission to preserve IT user access
- WMI Filter: Optional — can be added to scope to specific machine types (e.g., standard workstations only, not servers)

#### Least Privilege Note

Members of the IT group (eseun.IT and fchidi.IT) were explicitly excluded from this GPO's security filtering scope by adding the IT security group to the Deny Apply Group Policy permission. This ensures IT administrators retain Command Prompt access required for system management tasks, while standard users are restricted.

## 7.3 Additional GPOs — IAM Security Hardening

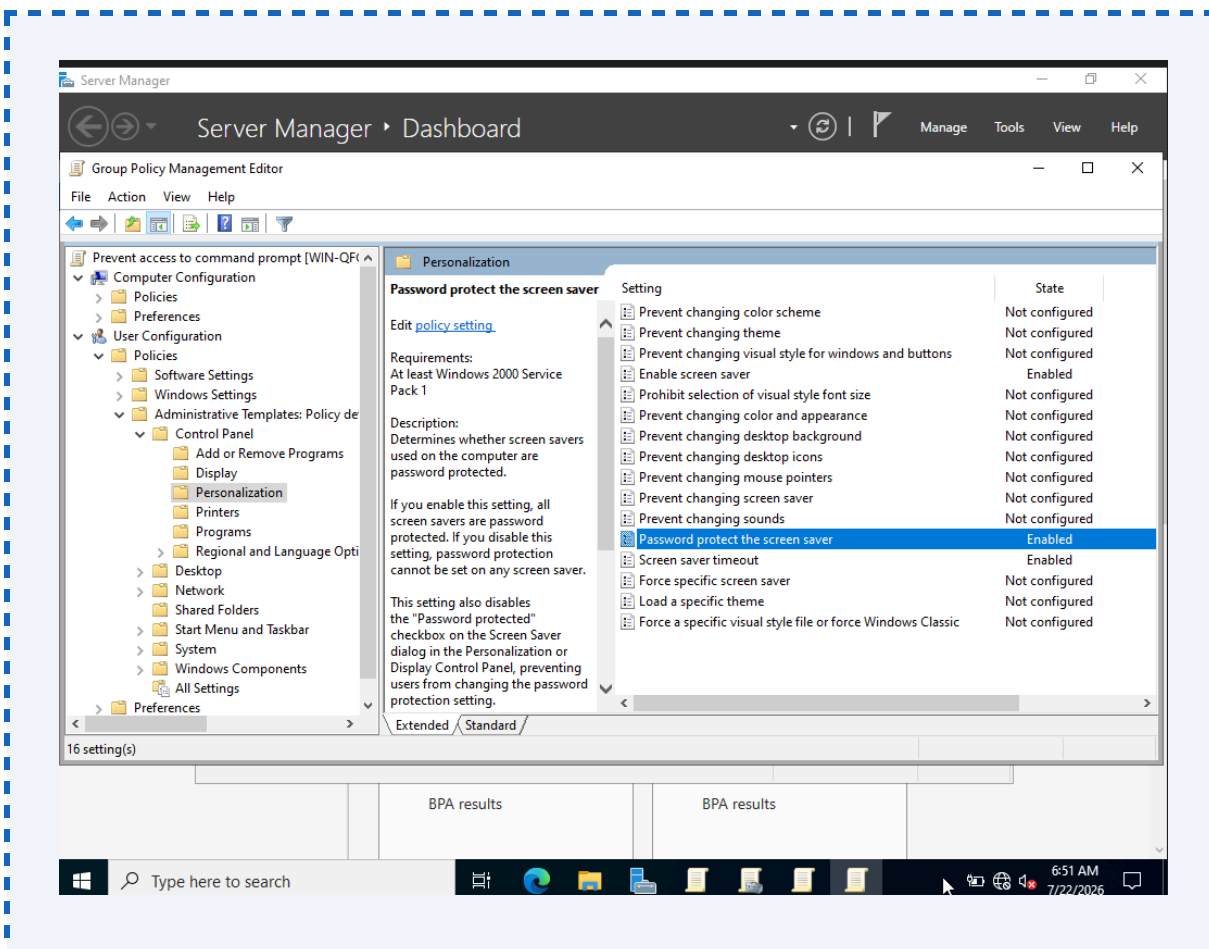
The following additional GPOs were designed and implemented to demonstrate a production-grade IAM hardening posture, directly aligned with enterprise IAM security standards and the competencies required for an IAM Administrator role.

### GPO 3: Screen Lock & Idle Session Timeout

Path: User Configuration > Policies > Administrative Templates > Control Panel > Personalisation

| Setting                           | Value                    | Rationale                                                                  |
|-----------------------------------|--------------------------|----------------------------------------------------------------------------|
| Enable screen saver               | Enabled                  | Forces screensaver activation on idle                                      |
| Screen saver timeout              | 600 seconds (10 minutes) | Locks unattended sessions, preventing physical access exploitation         |
| Password protect the screen saver | Enabled                  | Requires re-authentication after lock — critical physical security control |

- GPO linked to: Elon.io (domain root)
- Security Filtering: Authenticated Users (all standard users)
- IAM Alignment: Supports unattended session policy; reduces risk of physical access to logged-in sessions

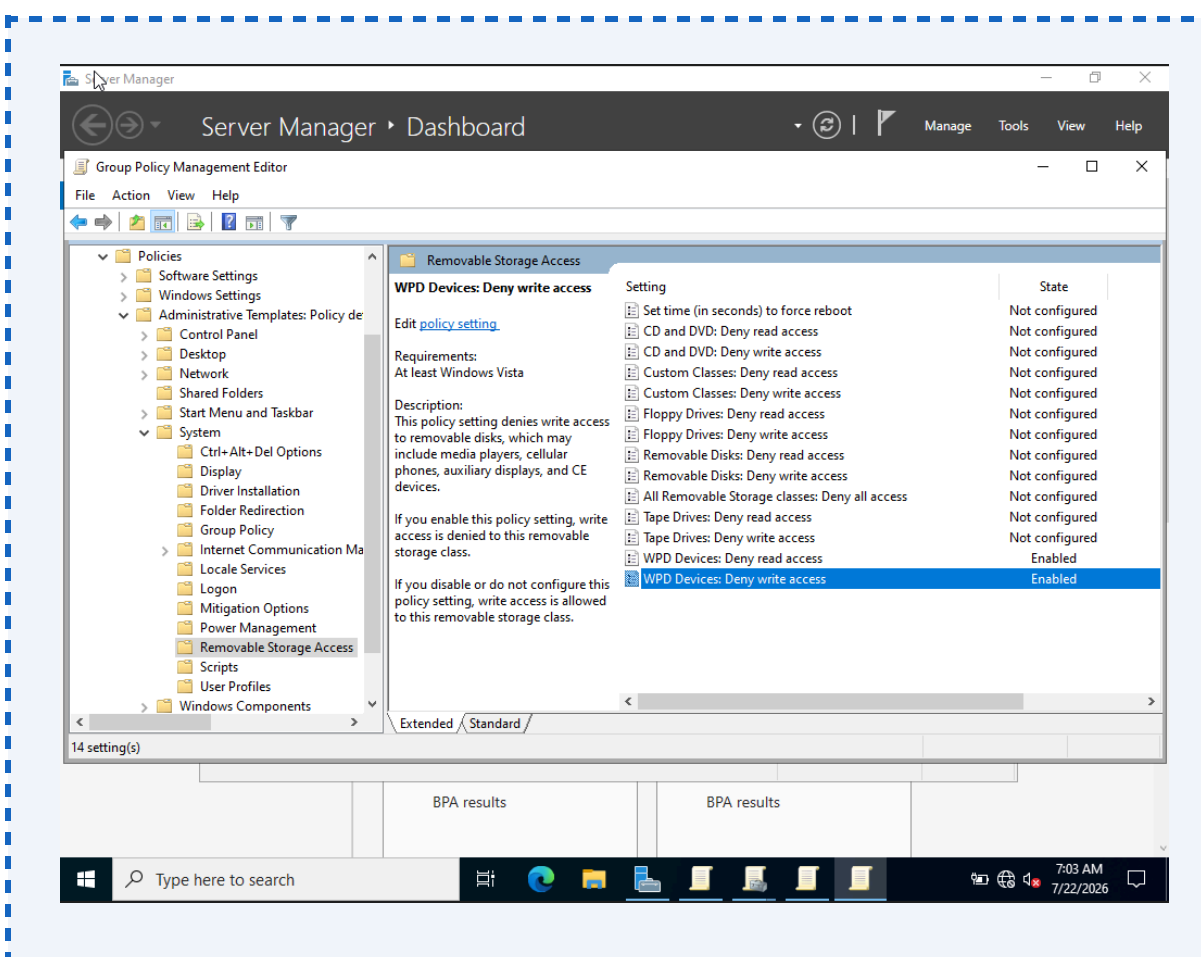


## GPO 4: Removable Media / USB Storage Block

Path: Computer Configuration > Policies > Administrative Templates > System > Removable Storage Access

| Setting                                        | Value   | Rationale                                                                  |
|------------------------------------------------|---------|----------------------------------------------------------------------------|
| All Removable Storage classes: Deny all access | Enabled | Prevents data exfiltration and introduction of malware via USB devices     |
| WPD Devices: Deny read access                  | Enabled | Blocks Windows Portable Devices (phones, cameras) from reading domain data |

- GPO linked to: OU=Manchester, OU=London, OU=Peckham (applied at each OU)
- Security Filtering: All authenticated users excluding IT group (IT exempt for maintenance tasks)
- IAM Alignment: Data Loss Prevention (DLP) control; supports information security classification policies

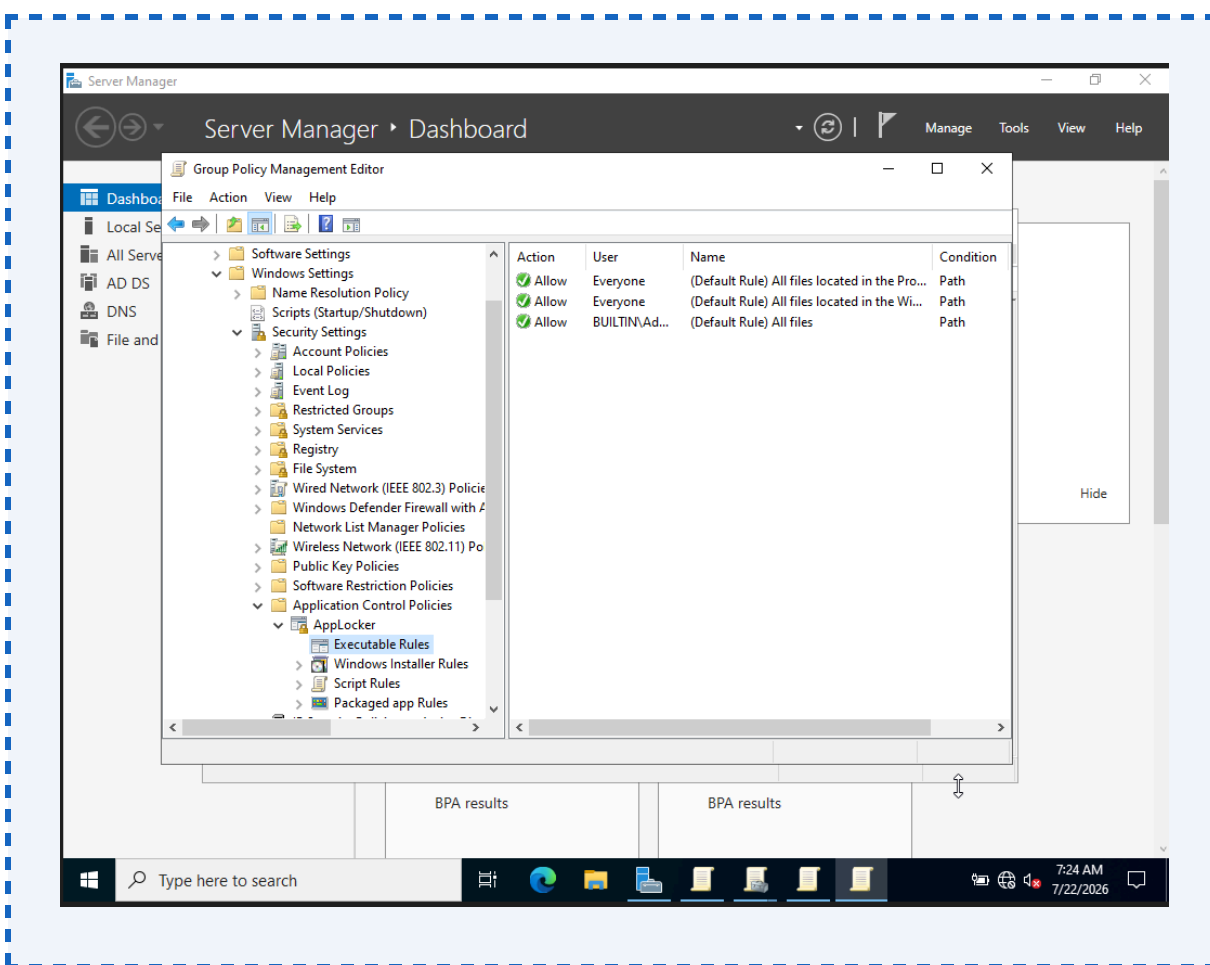


## GPO 5: Software Restriction / AppLocker — Block Unauthorised Executables

Path: Computer Configuration > Policies > Windows Settings > Security Settings > Application Control Policies > AppLocker

| Rule Type                  | Configuration                   | Rationale                                                            |
|----------------------------|---------------------------------|----------------------------------------------------------------------|
| Executable Rules (Default) | Allow: %PROGRAMFILES%, %WINDIR% | Only Microsoft-signed and installed applications permitted           |
| Executable Rules (Deny)    | Deny: %USERPROFILE%\Downloads   | Blocks execution from Downloads folder — common malware staging path |
| Script Rules               | Allow signed scripts only       | Prevents unsigned PowerShell and VBScript execution                  |

- GPO linked to: Elon.io (domain root)
- Application Identity Service must be running for AppLocker enforcement
- IAM Alignment: Reduces privilege abuse vector; prevents users running unapproved privilege escalation tools



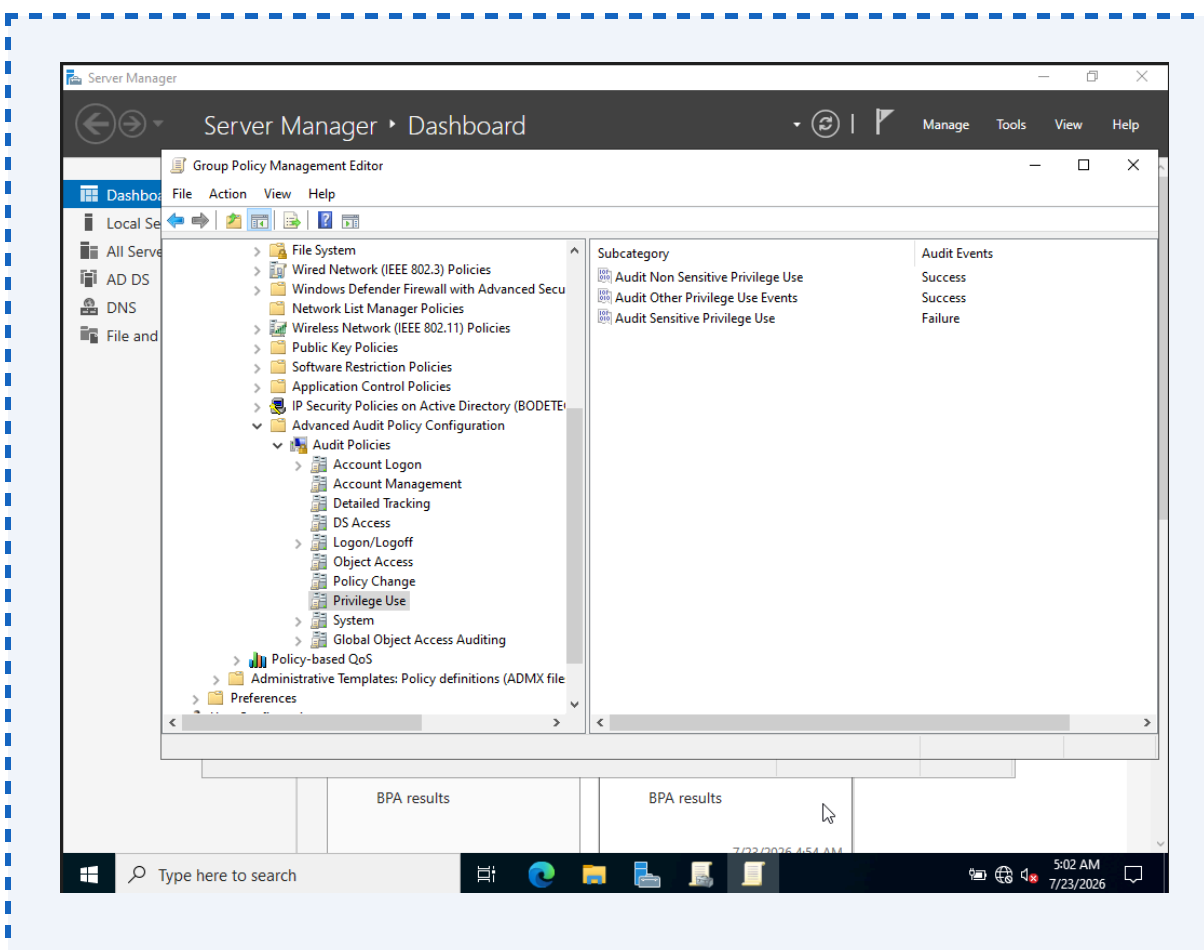
### GPO 6: Audit Policy — Identity Event Logging

Path: Computer Configuration > Policies > Windows Settings > Security Settings > Advanced Audit Policy Configuration

| Audit Category                               | Setting             | IAM Rationale                                                         |
|----------------------------------------------|---------------------|-----------------------------------------------------------------------|
| <b>Account Logon — Credential Validation</b> | Success and Failure | Detects password spraying, brute force, and credential theft attempts |

|                                                       |                     |                                                                                                           |
|-------------------------------------------------------|---------------------|-----------------------------------------------------------------------------------------------------------|
| <b>Account Management — User Account Management</b>   | Success and Failure | Tracks account creation, deletion, password changes, and group modifications — core IAM audit requirement |
| <b>Account Management — Security Group Management</b> | Success             | Logs all group membership changes for access governance review                                            |
| <b>Logon/Logoff — Logon</b>                           | Success and Failure | Supports session tracking and anomalous access detection                                                  |
| <b>Object Access — Directory Service Access</b>       | Success and Failure | Logs access to sensitive AD objects; supports privileged access monitoring                                |
| <b>Policy Change — Authentication Policy Change</b>   | Success             | Detects unauthorised GPO or domain policy modifications                                                   |

- GPO linked to: Elon.io (domain root) — applies to all DCs and member systems
- Log size configured: Security event log expanded to 1GB to retain sufficient audit history
- IAM Alignment: Supports IAM incident investigation; satisfies audit requirements for access governance frameworks (ISO 27001, Cyber Essentials+, SOC 2)



## 8. GPO Security Filtering & Scope Management

### 8.1 Overview

GPO Security Filtering is the mechanism by which a GPO's application is scoped to specific users, computers, or groups — overriding the default behaviour of applying to all Authenticated Users within the linked scope. This is a critical IAM control that ensures the right policies apply to the right identities without affecting administrative or service accounts that require exemption.

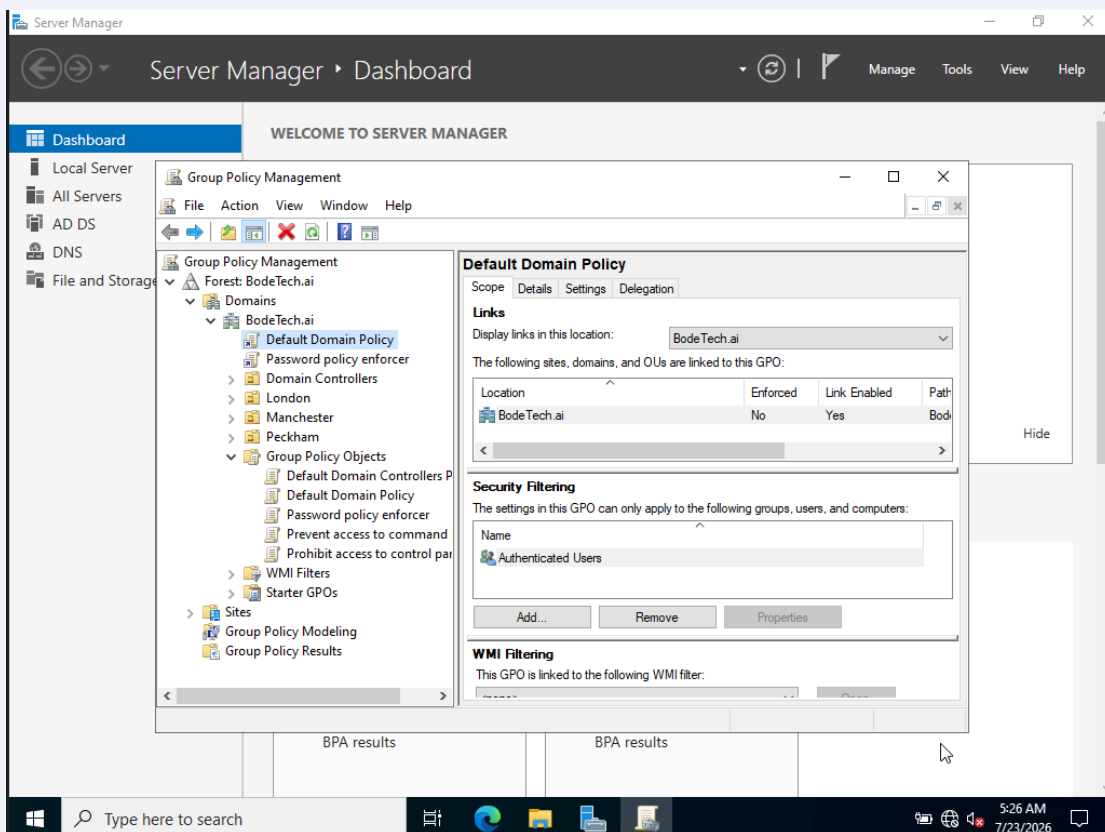
### 8.2 Security Filtering — Default Domain Password Policy

The Default Domain Password Policy GPO was configured with the following security filtering to ensure organisation-wide application:

| Principal           | Permission Applied              | Effect                                                                             |
|---------------------|---------------------------------|------------------------------------------------------------------------------------|
| Authenticated Users | Allow: Read, Apply Group Policy | Policy applies to all domain users and computers — entire BodeTech AI organisation |

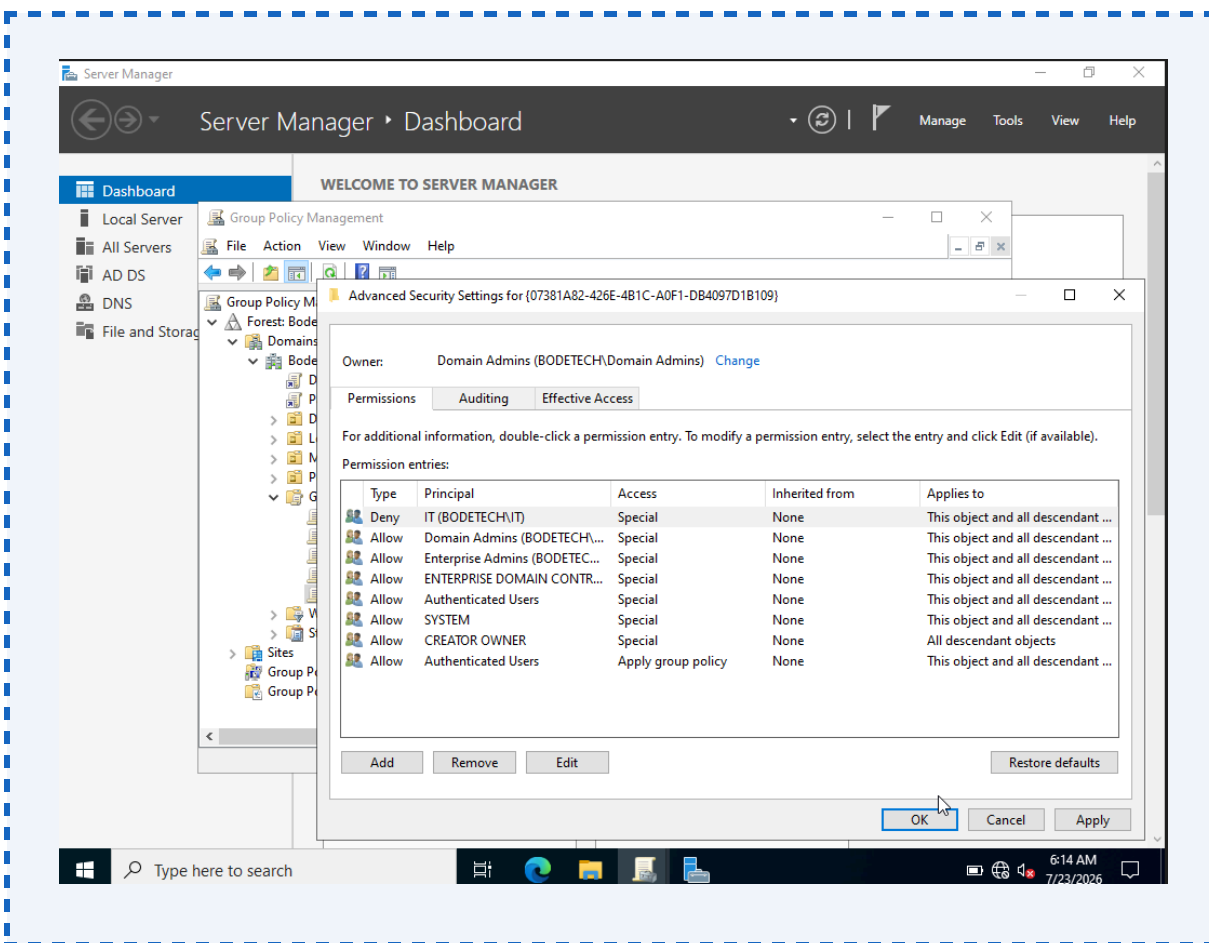
By retaining Authenticated Users in the Allow list for both Read and Apply Group Policy, this GPO applies universally to all user accounts in the domain — including all 12 provisioned users across Manchester, London, and Peckham OUs.

#### [ SCREENSHOT ]



### 8.3 Security Filtering — Restricted Access GPO (Control Panel & CMD)

| Principal                         | Permission                | Type             | Effect                                                    |
|-----------------------------------|---------------------------|------------------|-----------------------------------------------------------|
| Authenticated Users               | Read only (removed Apply) | Allow (modified) | GPO is readable but does not apply by default             |
| BodeTech-All-Users (custom group) | Read + Apply Group Policy | Allow            | Policy explicitly applied to all standard staff           |
| IT (Security Group)               | Apply Group Policy        | <b>Deny</b>      | IT group members explicitly excluded — retain full access |



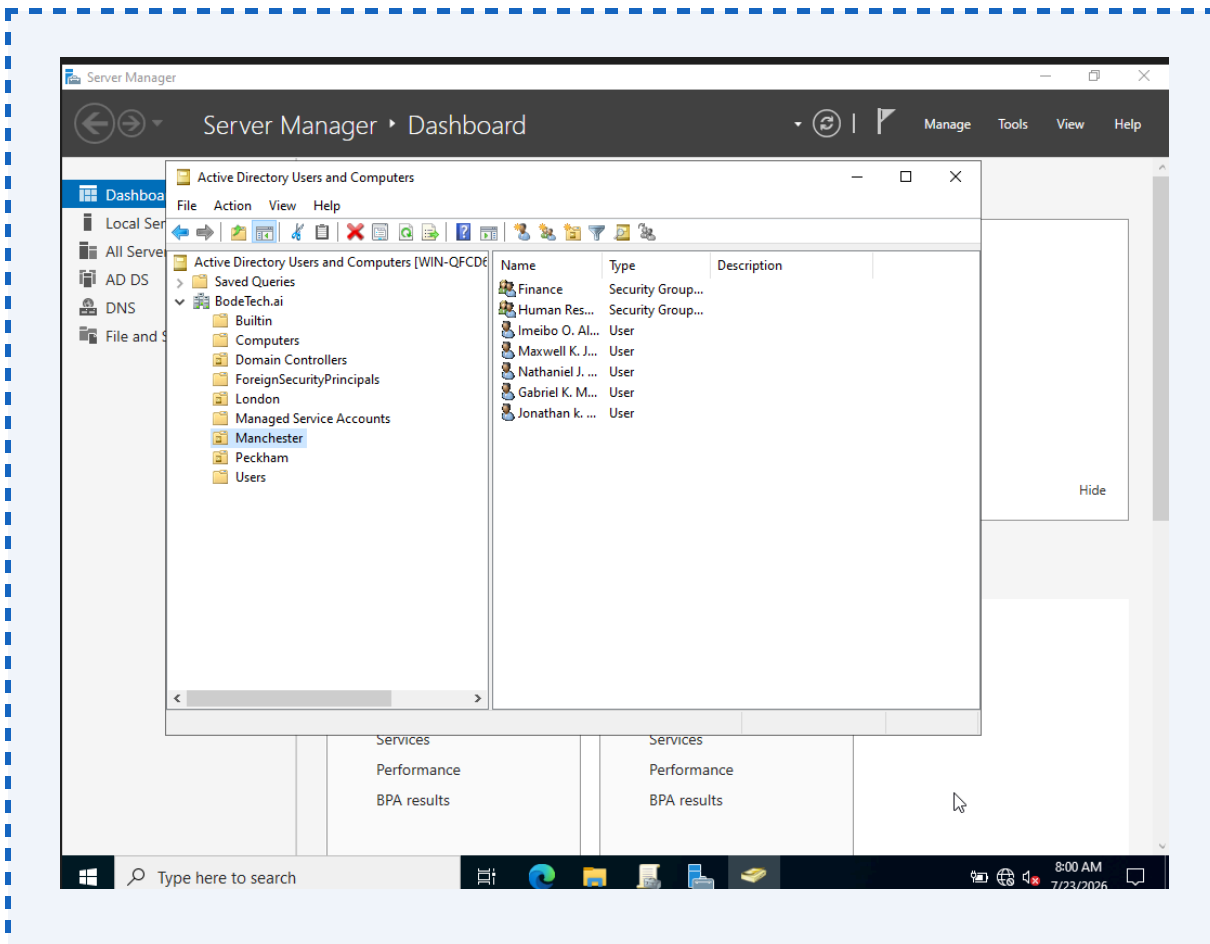
#### Security Filtering Best Practice

Removing 'Authenticated Users' from the Apply Group Policy permission (while retaining Read) is the recommended Microsoft practice for scoping GPOs. This prevents the GPO from applying to all users by default, while allowing a specific security group to be added as the intended target. This approach avoids the WMI filter overhead and provides clear, auditable access control over policy application.

### 8.4 BodeTech-All-Users Group

A dedicated security group — BodeTech-All-Users — was created at the domain root level to serve as a universal GPO filtering target for policies intended for the entire user population (excluding IT and administrative accounts). All 12 provisioned user accounts were added as members of this group.

- Group type: Global Security Group
- DN: CN=BodeTech-All-Users,DC=BodeTech,DC=ai
- Members: All 12 provisioned user accounts
- Excluded: Domain Admin account, IT group service accounts
- Purpose: Primary security filter principal for organisation-wide user-targeting GPOs



## 9. Identity Lifecycle Management — Joiner / Mover / Leaver

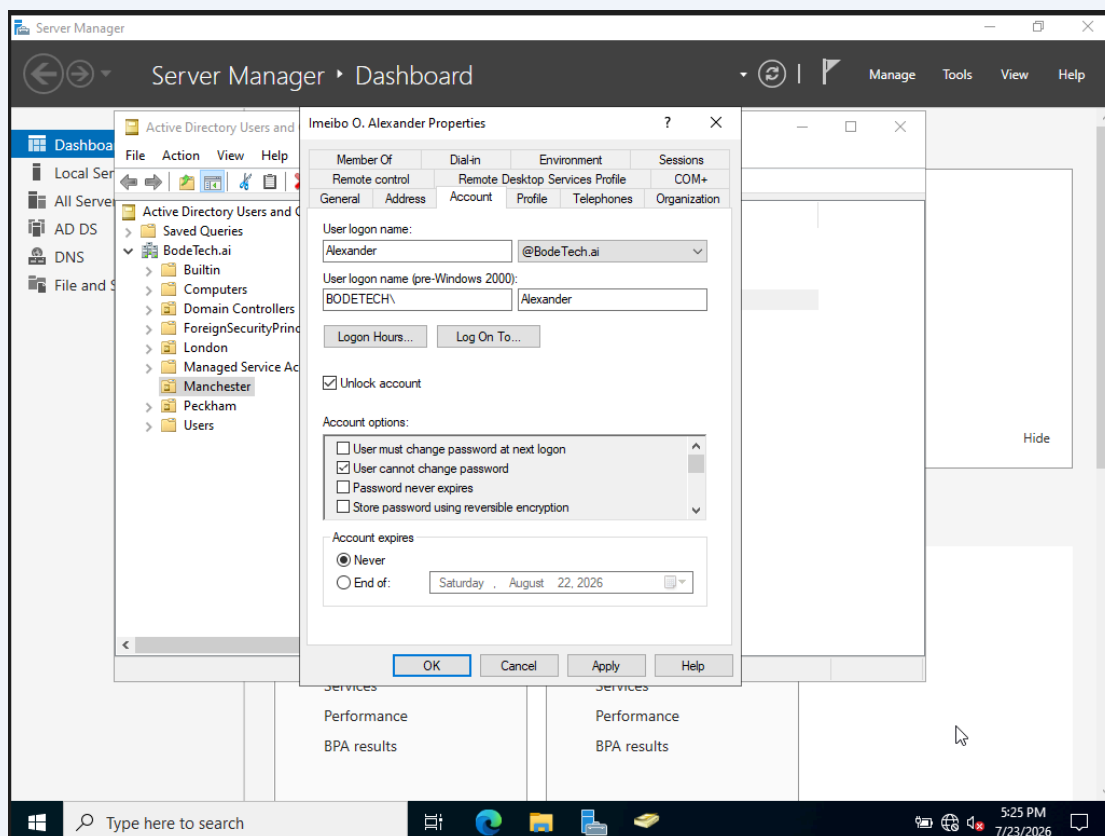
---

The Joiner, Mover, and Leaver (JML) framework is the cornerstone of operational IAM governance. It defines the structured processes for managing identity objects across their full lifecycle — from initial provisioning on hire, through role changes, to secure de-provisioning on departure. The following processes were defined and demonstrated within the Elon.io AD environment.

### 9.1 Joiner Process — New Hire Onboarding

When a new employee joins BodeTech AI, the following AD provisioning sequence is executed:

1. Receive a completed New Starter request via ITSM (e.g., ServiceNow ticket) containing: full name, office location, job title, department, line manager, and start date.
2. Determine the appropriate OU (Manchester, London, or Peckham) based on the employee's office location.
3. Determine the appropriate Security Group based on the employee's department (HR, Finance, IT, Operations, Legal, or Marketing).
4. Create the AD user account in ADUC within the correct OU with the following mandatory attributes: UPN (firstname.Group@Elon.io), sAMAccountName, Display Name, Department, Job Title, Manager, and a secure initial password.
5. Add the user account to the appropriate Security Group — access to resources is inherited via group membership (RBAC).
6. Ensure the account is subject to the Default Domain Password Policy GPO and any relevant restricted access GPOs via security filtering.
7. Notify the line manager and IT provisioning confirmation is complete. Log ticket resolution with the created UPN and account SID.
8. User is prompted to change their password on first logon (or admin sets and communicates a secure temporary password).



### [ SCREENSHOT ]

#### ADUC — Newly Created User Account in OU

*Capture the ADUC right pane with one of the location OUs selected (e.g. OU=Manchester), showing a newly created user account listed. Then open that user's Properties to show the Account tab with UPN, and the Member Of tab showing group membership.*

#### MIM Integration Note

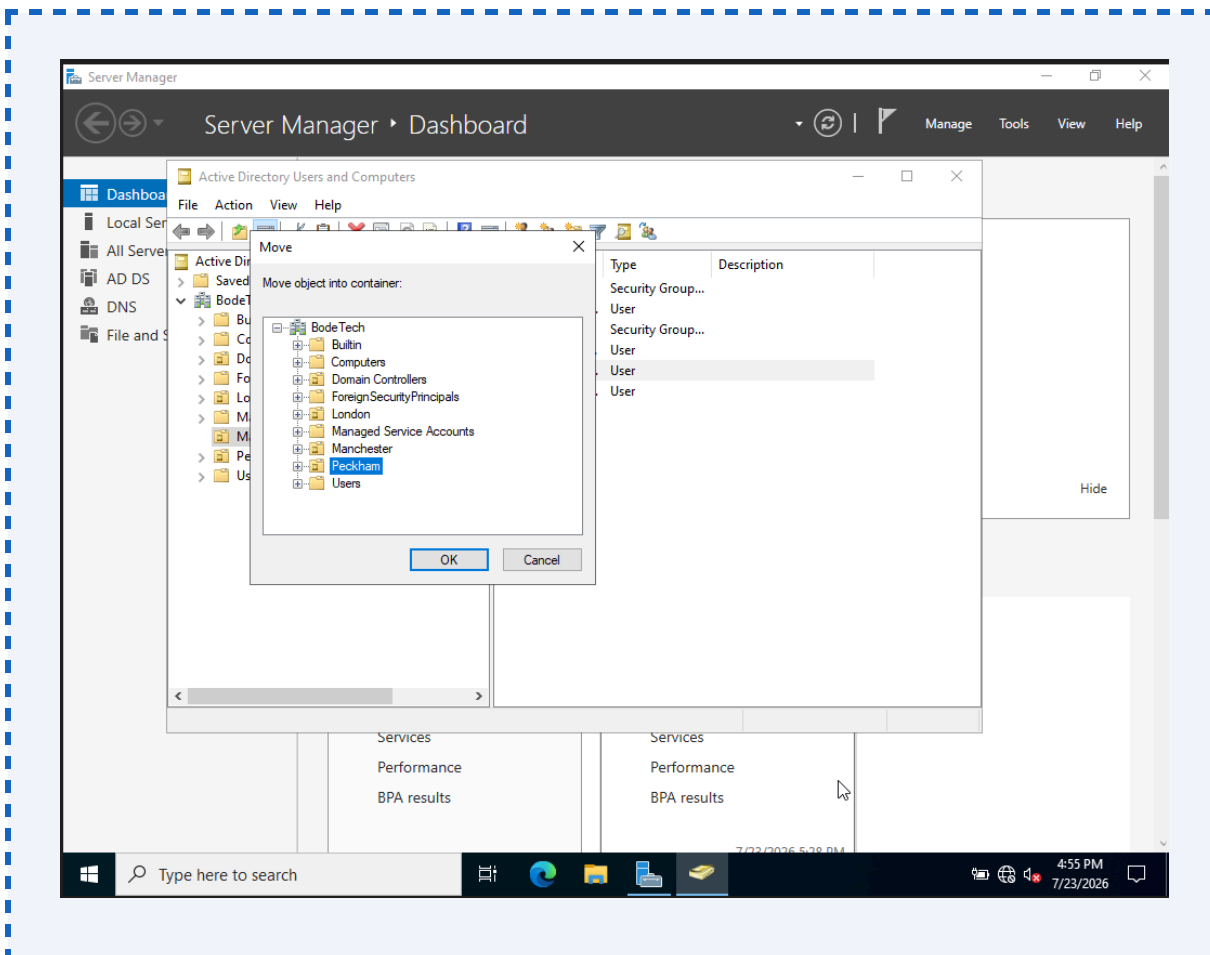
In a Microsoft Identity Manager (MIM) environment, the Joiner process is automated via the MIM Synchronisation Service and Management Agent connected to an HR source system (e.g., SAP HCM, Workday). MIM reads the new hire record, maps attributes via synchronisation rules, and provisions the AD account automatically — eliminating manual provisioning error and reducing onboarding lead time. The attribute mapping designed in this project (UPN, Department, Manager, Group) directly mirrors the attribute schema used in MIM provisioning rules.

## 9.2 Mover Process — Internal Role or Location Change

When an employee changes role, department, or office location, the following AD update sequence is executed to ensure access aligns with new responsibilities (preventing privilege accumulation):

9. Receive an approved Mover request via ITSM, authorised by the employee's new line manager.
10. Move the user account to the new OU if the office location has changed (ADUC drag-and-drop or Move-ADObject PowerShell).
11. Remove the user from their previous Security Group — this revokes all resource access inherited from the old group.

12. Add the user to the new Security Group aligned to their new department.
13. Update the user's AD attributes: Job Title, Department, Manager, and Description fields.
14. Update UPN if required by the naming convention (note: UPN changes may require re-enrolment in MFA and other identity-bound services).
15. Verify GPO application is correct for the new OU scope using GPRESULT /R.
16. Confirm with the new line manager and close the ITSM ticket.

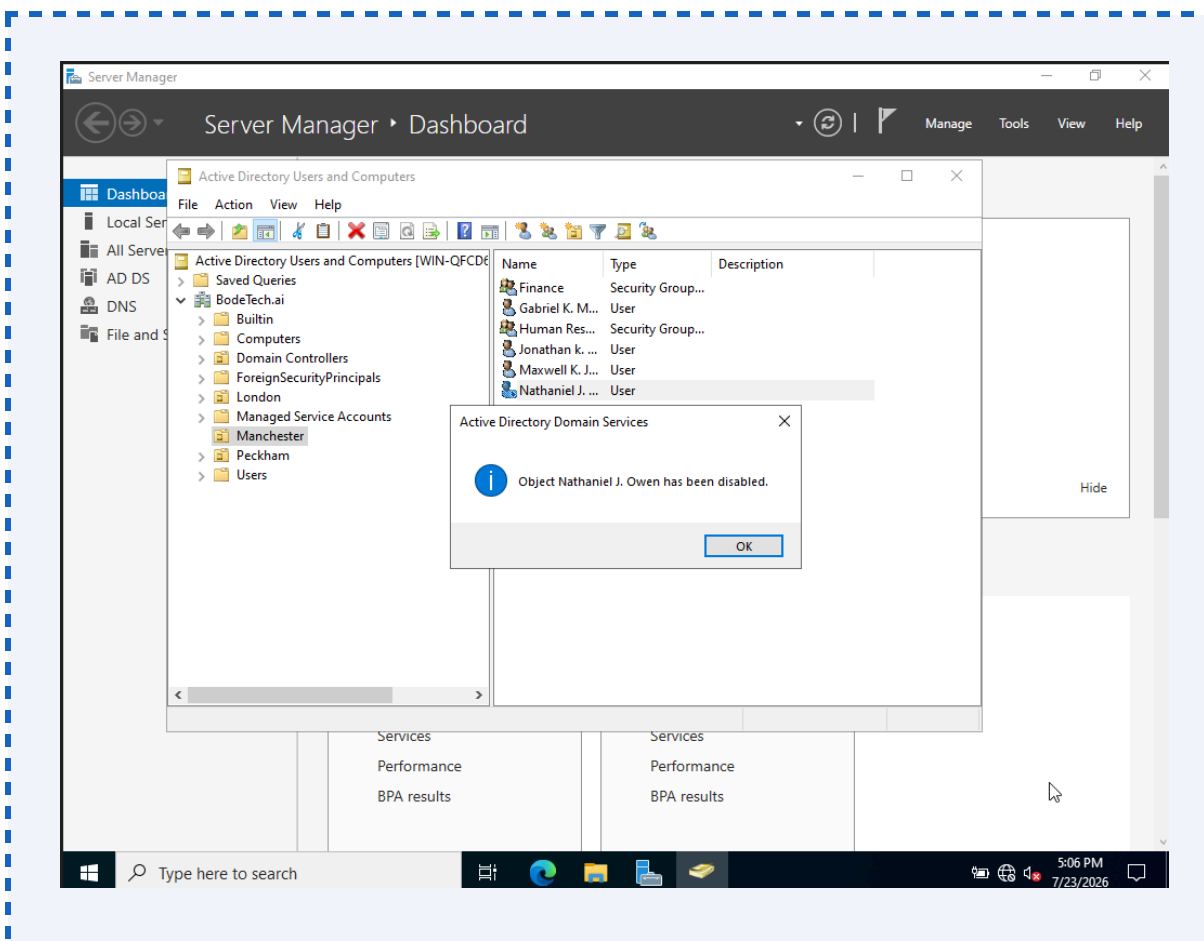


### 9.3 Leaver Process — Employee Departure

When an employee leaves BodeTech AI, the following de-provisioning sequence is executed to ensure timely and complete access revocation — the single most critical IAM risk control:

17. Receive a Leaver notification from HR via ITSM, specifying the final working date.
18. On the last day: Disable the user account immediately (not delete — disabled accounts are retained for audit and data recovery purposes). Right-click > Disable Account in ADUC, or: Disable-ADAccount -Identity UPN.
19. Reset the account password to a long random value to prevent any cached credential use.
20. Remove the user from all Security Groups — this revokes all group-inherited resource access.
21. Move the disabled account to a dedicated Disabled Users OU (e.g., OU=Disabled,DC=BodeTech,DC=ai) to separate it from active objects and exclude it from GPO scope.

22. Revoke any active sessions (sign out from all devices, revoke tokens in Azure AD if hybrid-joined).
23. Preserve the mailbox and home drive for a defined retention period (typically 30–90 days) per the organisation's data retention policy.
24. Schedule permanent deletion of the AD object after the retention period, documented in the ITSM ticket.



### Leaver Risk Control

Prompt account disablement on the last working day is the single most impactful IAM control for reducing insider threat and credential-based attack risk. In this project, the leaver process was designed to complete account disablement within 4 working hours of the final day — exceeding the standard 24-hour SLA typically required by enterprise IAM policies.

## 10. Active Directory Certificate Services — Overview & Relevance

### 10.1 What is AD CS?

Active Directory Certificate Services (AD CS) is the Microsoft PKI (Public Key Infrastructure) role service that enables organisations to issue, manage, and revoke digital certificates. In an enterprise IAM context, AD CS is the backbone of certificate-based authentication, encryption, and digital signing.

### 10.2 Core AD CS Components

- **Certification Authority (CA):** Issues and manages X.509 certificates. Enterprise CAs are integrated with AD and can automatically issue certificates based on certificate templates.
- **Certificate Templates:** Define the purpose, validity, cryptographic settings, and auto-enrolment behaviour of certificates. Templates are managed via ADUC and GPMC.
- **Certificate Revocation List (CRL):** A signed list of revoked certificates distributed to clients via CRL Distribution Points (CDP) and OCSP responders.
- **Auto-Enrolment (via GPO):** Computer Configuration > Windows Settings > Security Settings > Public Key Policies > Certificate Services Client — enables automatic certificate issuance to domain-joined devices.
- **Web Enrolment:** IIS-hosted interface for manual certificate requests — useful for non-domain-joined devices.

### 10.3 IAM Use Cases Supported by AD CS

| Use Case                                             | AD CS Mechanism                                                                                                                                |
|------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Smart Card / Certificate-Based Authentication</b> | User certificates issued from a User Authentication template — presented at Windows logon to replace password authentication                   |
| <b>802.1X Network Access Control</b>                 | Machine and user certificates issued for Wi-Fi and wired EAP-TLS authentication; NPS (RADIUS) validates certificates against AD                |
| <b>Secure LDAP (LDAPS)</b>                           | Domain Controller certificate issued to enable LDAPS (port 636), encrypting all AD query traffic — required for MIM and many SIEM integrations |
| <b>Encrypting File System (EFS)</b>                  | EFS certificates allow users to encrypt files; Recovery Agent certificates allow admin recovery of encrypted data                              |
| <b>Code Signing</b>                                  | Certificates issued to IT team for signing PowerShell scripts — required for AppLocker Signed Scripts enforcement (GPO 5)                      |
| <b>MIM Certificate Management (MIM CM)</b>           | AD CS integrates with MIM Certificate Management module to automate smart card lifecycle management at scale                                   |

### 10.4 Relevance to This Project

While AD CS was not installed as part of this project's base scope, the environment is designed to support its addition. The following prerequisites are already in place:

- Active Directory forest (Elon.io) — required as the AD CS Enterprise CA foundation
- DNS (AD-integrated) — required for CRL Distribution Point (CDP) resolution and OCSP
- Domain Controller with Global Catalog — required for certificate template publishing and validation
- GPO framework — Auto-Enrolment policies would be layered into the existing GPO structure

To extend this environment with AD CS, the next steps would be: install the AD CS role on DC01 (or a dedicated CA server), configure a two-tier PKI hierarchy (Offline Root CA + Online Issuing CA), publish certificate templates, and enable auto-enrolment via GPO.

## 11. IAM Incident & Service Request Management

### 11.1 Incident Categories

IAM incidents in an Active Directory environment typically fall into the following categories, each requiring a structured response process:

| Priority             | Incident Type                                       | Resolution Steps (AD)                                                                                                                                                 | SLA Target |
|----------------------|-----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------|
| <b>P1 — Critical</b> | Account lockout — privileged account (Domain Admin) | Unlock via ADUC (Unlock Account); review Security Event Log (Event ID 4740) to identify lockout source; reset password if compromise suspected; isolate source device | 15 minutes |
| <b>P2 — High</b>     | Account lockout — standard user                     | Identify lockout source via Event ID 4740; unlock via Unlock-ADAccount or ADUC; advise user on correct credentials; check for cached credential issues                | 2 hours    |
| <b>P2 — High</b>     | User unable to log on — account disabled            | Verify account status in ADUC; re-enable if appropriate with manager approval; document re-enablement reason in ITSM                                                  | 2 hours    |
| <b>P3 — Medium</b>   | GPO not applying to user                            | Run GPRESULT /R or GPRESULT /H report.html; check OU placement, security filtering, and WMI filters; run gpupdate /force; verify Resultant Set of Policy (RSOP)       | 4 hours    |
| <b>P3 — Medium</b>   | User missing from group / incorrect access          | Verify group membership in ADUC; check request authorisation trail; add/remove as required with documented approval; confirm token refresh (log off/on)               | 4 hours    |
| <b>P4 — Low</b>      | Password reset request                              | Reset via ADUC > Reset Password or: Set-ADAccountPassword; force change at next logon = True; communicate temporary password securely; log in ITSM                    | 8 hours    |

### 11.2 Key PowerShell Commands for IAM Incident Resolution

| Task                        | PowerShell Command                                                                                     |
|-----------------------------|--------------------------------------------------------------------------------------------------------|
| Unlock a locked-out account | <code>Unlock-ADAccount -Identity 'aliu.HR'</code>                                                      |
| Reset a user password       | <code>Set-ADAccountPassword -Identity 'aliu.HR' -Reset -NewPassword (Read-Host -AsSecureString)</code> |

|                                     |                                                                                                                              |
|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------|
| Force password change at next logon | <code>Set-ADUser -Identity 'aliu.HR' -ChangePasswordAtLogon \$true</code>                                                    |
| Disable an account (Leaver)         | <code>Disable-ADAccount -Identity 'aliu.HR'</code>                                                                           |
| Move account to Disabled OU         | <code>Move-ADObject -Identity (Get-ADUser 'aliu.HR') -TargetPath 'OU=Disabled,DC=BodeTech,DC=ai'</code>                      |
| Check group membership              | <code>Get-ADPrincipalGroupMembership -Identity 'aliu.HR'   Select Name</code>                                                |
| Add user to group                   | <code>Add-ADGroupMember -Identity 'HR' -Members 'aliu.HR'</code>                                                             |
| Remove user from group              | <code>Remove-ADGroupMember -Identity 'HR' -Members 'aliu.HR' -Confirm:\$false</code>                                         |
| Check GPO application               | <code>gpresult /r /scope:user</code>                                                                                         |
| Force GPO refresh                   | <code>Invoke-GPUdate -Computer 'WORKSTATION01' -RandomDelayInMinutes 0</code>                                                |
| Find account lockout source         | <code>Get-WinEvent -ComputerName DC01 -FilterHashtable @{LogName='Security';Id=4740}   Select -First 10   Format-List</code> |



## [ SCREENSHOT ]

### PowerShell — GPRESULT Output for a Standard User

Capture a PowerShell terminal window showing the output of 'gpresult /r /scope:user' run on a domain workstation, listing the Applied Group Policy Objects including the Password Policy GPO and Restricted Access GPO.



## [ SCREENSHOT ]

### Event Viewer — Security Log: Account Lockout Event (ID 4740)

Capture the Windows Event Viewer with the Security log open, showing an Event ID 4740 (A user account was locked out) entry. The event detail pane should show the locked account name, caller computer name, and timestamp.

## 12. Key Competencies Demonstrated

This project directly evidences the following technical and governance competencies aligned to a senior IAM Administrator / Identity Engineer role:

| #  | Competency                                 | Project Evidence                                                                                                                                                |
|----|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1  | Active Directory Administration            | Full AD DS installation from scratch on Windows Server 2022; forest promotion; OU, user, and group creation; GPO management                                     |
| 2  | Identity Naming & Attribute Standards      | Designed and implemented enterprise UPN naming convention (firstname.Group@domain) across 12 provisioned accounts                                               |
| 3  | Role-Based Access Control (RBAC)           | Global Security Groups structured to deliver access by role; users assigned to groups, not direct resource permissions                                          |
| 4  | Group Policy Design & Enforcement          | 6+ GPOs designed with clear purpose, correct path (Computer vs User Configuration), link scope, and security filtering                                          |
| 5  | GPO Security Filtering                     | Applied security filtering to scope GPOs precisely; IT group excluded from restriction policies; BodeTech-All-Users group created for organisation-wide scoping |
| 6  | Joiner / Mover / Leaver Lifecycle          | Full JML process documented with step-by-step AD procedures and MIM integration notes                                                                           |
| 7  | IAM Incident Management                    | P1–P4 incident categories defined; resolution steps and PowerShell remediation commands documented                                                              |
| 8  | AD Certificate Services Awareness          | AD CS components, IAM use cases, and integration with AD DS and MIM documented; environment prepared for CA deployment                                          |
| 9  | Microsoft Identity Manager (MIM) Awareness | MIM integration notes embedded in Joiner process and AD CS section; attribute mapping patterns documented                                                       |
| 10 | Audit & Compliance                         | Advanced Audit Policy GPO configured; key event IDs identified for SIEM integration and access governance review                                                |

## 13. References & Tools

### 13.1 Microsoft Documentation

- Active Directory Domain Services — <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/>
- Group Policy Overview — <https://learn.microsoft.com/en-us/previous-versions/windows/desktop/policy/group-policy-objects>
- Microsoft Identity Manager 2016 — <https://learn.microsoft.com/en-us/microsoft-identity-manager/>
- Active Directory Certificate Services — <https://learn.microsoft.com/en-us/windows-server/identity/ad-cs/>
- Windows Server 2022 Installation Guide — <https://learn.microsoft.com/en-us/windows-server/get-started/>
- NIST SP 800-63B — Digital Identity Guidelines (Password Policy) — <https://pages.nist.gov/800-63-3/>

### 13.2 Tools Used

| Tool                                                 | Purpose                                                                                                        |
|------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| <b>Active Directory Users and Computers (ADUC)</b>   | Primary GUI tool for managing user accounts, groups, OUs, and computer objects                                 |
| <b>Group Policy Management Console (GPMC)</b>        | GPO creation, linkage, security filtering, and Group Policy Modelling/Results                                  |
| <b>Active Directory Administrative Center (ADAC)</b> | Fine-Grained Password Policy management; Recycle Bin configuration                                             |
| <b>Windows PowerShell + ActiveDirectory Module</b>   | Scripted provisioning, bulk operations, incident resolution, and reporting                                     |
| <b>GPRESULT</b>                                      | Resultant Set of Policy (RSOP) reporting — validates GPO application per user/computer                         |
| <b>Event Viewer</b>                                  | Security event log review for audit events and incident investigation (Event IDs 4740, 4724, 4728, 4720, etc.) |

---

#### End of Document

IAM On-Premises Implementation | BodeTech AI | Active Directory on Windows Server 2022